

Introduction

- ❖ Burp Suite is a powerful cybersecurity tool
- ❖ Used for web application security testing
- ❖ Ethical hackers and security experts use it to find vulnerabilities
- ❖ It works as a man-in-the-middle between browser and web server

Why Use Burp Suite?

- ❖ To find and fix security vulnerabilities in websites
- ❖ To intercept and analyze HTTP/S requests and response
- ❖ For both manual and automated testing
- ❖ Helps strengthen website security and prevent cyberattacks

Main Features of Burp Suite

Tool	Purpose
Proxy	Intercepts traffic between browser & server
Spider	Crawls the website and maps its structure
Scanner	Automatically finds vulnerabilities (Pro only)
Intruder	Performs brute-force or input testing
Repeater	Sends the same request repeatedly with changes
Decoder	Encodes/decodes data
comparer	Compares requests and responses

VWA – Damn Vulnerable Web Application

DVWA is a deliberately insecure web application built for learning and testing web security.

Purpose:

To provide a safe environment to test tools like Burp Suite, OWASP ZAP, etc.

Used for practicing real-world attacks like:

- ❖ SQL Injection
 - ❖ Cross-Site Scripting (XSS)
 - ❖ Command Injection and more
-

Install docker and docker compose

Install docker

Open terminal and run:

- ❖ `sudo apt update`
- ❖ `Sudo apt install docker.io -y`

Start and enable docker

- ❖ `Sudo systemctl start docker`
- ❖ `Sudo system ctl enable docker`

Install docker compose

- ❖ `Sudo apt install docker compose -y`

Create docker compose file for dvwa

Create a project directory

```
mk dir dvwa-docker && cd dvwa-docker
```

Create a docker-compose -.yaml file

```
nano docker-compose.yaml
```

Paste the following into it

```
version: '3'
```

```
services:
```

```
  dvwa:
```

image: vulnerables/web-dvwa

ports:

“8080:80”

Start the container

docker-compose up -d

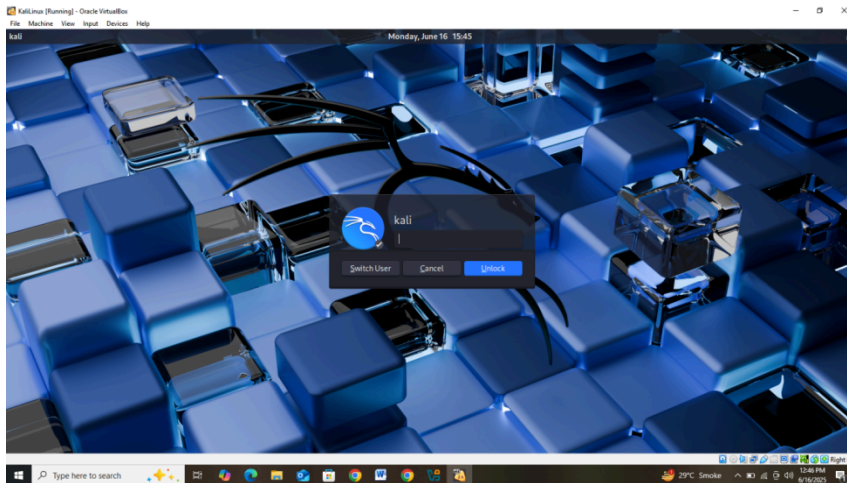
```
(kali㉿kali)-[~/dvwa-docker]
$ docker-compose up -d
WARN[0000] /home/kali/dvwa-docker/docker-compose.yml: the attribute `version`
is obsolete, it will be ignored, please remove it to avoid potential confusi
on
permission denied while trying to connect to the Docker daemon socket at unix
:///var/run/docker.sock: Get "http://%2Fvar%2Frun%2Fdocker.sock/v1.45/contain
ers/json?all=1&filters=%7B%22label%22%3A%7B%22com.docker.compose.config-hash%
22%3Atrue%2C%22com.docker.compose.project%3Ddvwa-docker%22%3Atrue%7D%7D": dia
l unix /var/run/docker.sock: connect: permission denied

(kali㉿kali)-[~/dvwa-docker]
$ sudo docker-compose up -d
WARN[0000] /home/kali/dvwa-docker/docker-compose.yml: the attribute `version`
is obsolete, it will be ignored, please remove it to avoid potential confusi
on
[+] Running 9/9
 ✓ dvwa Pulled                                299.0s
   ✓ 3e17c6eae66c Pull complete                120.7s
   ✓ 0c57df616dbf Pull complete                244.2s
   ✓ eb05d18be401 Pull complete                 1.5s
   ✓ e9968e5981d2 Pull complete                10.9s
   ✓ 2cd72dba8257 Pull complete                12.2s
   ✓ 6cff5f35147f Pull complete                15.7s
   ✓ 098cffd43466 Pull complete                19.0s
   ✓ b3d64a33242d Pull complete                20.9s
[+] Running 2/2
 ✓ Network dvwa-docker_default    Creat ...    0.5s
 ✓ Container dvwa-docker-dvwa-1   Star ...    2.2s

(kali㉿kali)-[~/dvwa-docker]
$
```

Complete installation of Docker.io

Open the virtual box and login into system



```
File Actions Edit View Help
(kali@kali)-[~]
$ sudo apt update
[sudo] password for kali:
Get:1 http://kali.download/kali kali-rolling InRelease [41.5 kB]
Get:2 http://kali.download/kali kali-rolling/main amd64 Packages [21.0 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [51.4 MB]
Get:4 http://kali.download/kali kali-rolling/contrib amd64 Packages [120 kB]
Get:5 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [32 7 kB]
Get:6 http://kali.download/kali kali-rolling/non-free amd64 Packages [197 kB]
Get:7 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [9 11 kB]
Get:8 http://kali.download/kali kali-rolling/non-free-firmware amd64 Packages [10.6 kB]
Get:9 http://kali.download/kali kali-rolling/non-free-firmware amd64 Contents (deb) [26.4 kB]
Fetched 74.0 MB in 2min 56s (421 kB/s)
157 packages can be upgraded. Run 'apt list --upgradable' to see them.
```



```
(kali@kali)-[~]
$ sudo apt install docker.io -y
Installing:
docker.io

Installing dependencies:
containerd      libcompel1      libproc-processtable-perl  runc
criu            libintl-perl    libsort-naturally-perl    tini
docker-buildx  libintl-xs-perl  needrestart
docker-cli     libmodule-find-perl  python3-pycru

Suggested packages:
containernetworking-plugins  cgroupfs-mount  xfsprogs
docker-doc                   debotstrap      zfs-fuse
aufs-tools                   rinse           | zfsutils-linux
btrfs-progs                  rootlesskit

Summary:
Upgrading: 0, Installing: 15, Removing: 0, Not Upgrading: 157
Download size: 81.4 MB
Space needed: 335 MB / 63.8 GB available

Get:1 http://kali.kali.org/kali kali-rolling/main amd64 runc amd64 1.1.15+ds1
~2+b3 [3,229 kB]
Get:4 http://kali.kali.org/kali kali-rolling/main amd64 docker.io amd64 26.1.
5+dfsg1-9+b6 [23.0 MB]
Get:5 http://mirror.kku.ac.th/kali kali-rolling/main amd64 libcompel1 amd64 4
.1-1 [64.0 kB]
Get:2 http://kali.kali.org/kali kali-rolling/main amd64 containerd amd64 1.7.
24-ds1-6+b2 [32.8 MB]
Get:3 http://kali.download/kali kali-rolling/main amd64 tini amd64 0.19.0-3 [
280 kB]
Get:6 http://kali.download/kali kali-rolling/main amd64 criu amd64 4.1-1 [560
kB]
```

```
(kali@kali)-[~]
$ sudo systemctl start docker
```

```
(kali@kali)-[~]
$ sudo systemctl enable docker
Synchronizing state of docker.service with SysV service script with /usr/lib/
systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable docker
```

```
(kali@kali)-[~]
$ sudo apt install docker-compose -y
Installing:
docker-compose

Summary:
Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 157
Download size: 13.0 MB
Space needed: 64.4 MB / 63.5 GB available

Get:1 http://kali.download/kali kali-rolling/main amd64 docker-compose amd64
2.26.1-4 [13.0 MB]
Fetched 13.0 MB in 22s (592 kB/s)
Selecting previously unselected package docker-compose.
(Reading database ... 413432 files and directories currently installed.)
Preparing to unpack .../docker-compose_2.26.1-4_amd64.deb ...
Unpacking docker-compose (2.26.1-4) ...
Setting up docker-compose (2.26.1-4) ...
Processing triggers for kali-menu (2025.2.7) ...
Processing triggers for man-db (2.13.1-1) ...
Scanning processes ...
Scanning linux images ...

Running kernel seems to be up-to-date.

No services need to be restarted.

No containers need to be restarted.
```

```

(kali㉿kali)-[~]
$ mkdir dvwa-docker && cd dvwa-docker

(kali㉿kali)-[~/dvwa-docker]
$ nano docker-compose.yml

(kali㉿kali)-[~/dvwa-docker]
$ cd

(kali㉿kali)-[~]
$ ls
Desktop  Downloads  Music  Public  Videos
Documents  dvwa-docker  Pictures  Templates

(kali㉿kali)-[~]
$ docker-compose up -d
no configuration file provided: not found

(kali㉿kali)-[~]
$ cd dvwa-docker

(kali㉿kali)-[~/dvwa-docker]
$ ls
docker-compose.yml

```

```

(kali㉿kali)-[~/dvwa-docker]
$ docker-compose up -d
WARN[0000] /home/kali/dvwa-docker/docker-compose.yml: the attribute `version`
is obsolete, it will be ignored, please remove it to avoid potential confusi
on
permission denied while trying to connect to the Docker daemon socket at unix
:///var/run/docker.sock: Get "http://%2Fvar%2Frun%2Fdocker.sock/v1.45/contain
ers/json?all=1&filters=%7B%22label%22%3A%7B%22com.docker.compose.config-hash%
22%3Atrue%2C%22com.docker.compose.project%3Ddvwa-docker%22%3Atrue%7D%7D": dia
l unix /var/run/docker.sock: connect: permission denied

(kali㉿kali)-[~/dvwa-docker]
$ sudo docker-compose up -d
WARN[0000] /home/kali/dvwa-docker/docker-compose.yml: the attribute `version`
is obsolete, it will be ignored, please remove it to avoid potential confusi
on
[+] Running 9/9
✔ dvwa Pulled
✔ 3e17c6eae66c Pull complete 299.0s
✔ 0c57df616dbf Pull complete 120.7s
✔ eb05d18be401 Pull complete 244.2s
✔ e9968e5981d2 Pull complete 1.5s
✔ 2cd72dba8257 Pull complete 10.9s
✔ 6cff5f35147f Pull complete 12.2s
✔ 098cffd43466 Pull complete 15.7s
✔ b3d64a33242d Pull complete 19.0s
[+] Running 2/2
✔ Network dvwa-docker_default Creat... 0.5s
✔ Container dvwa-docker-dvwa-1 Star... 2.2s

(kali㉿kali)-[~/dvwa-docker]
$

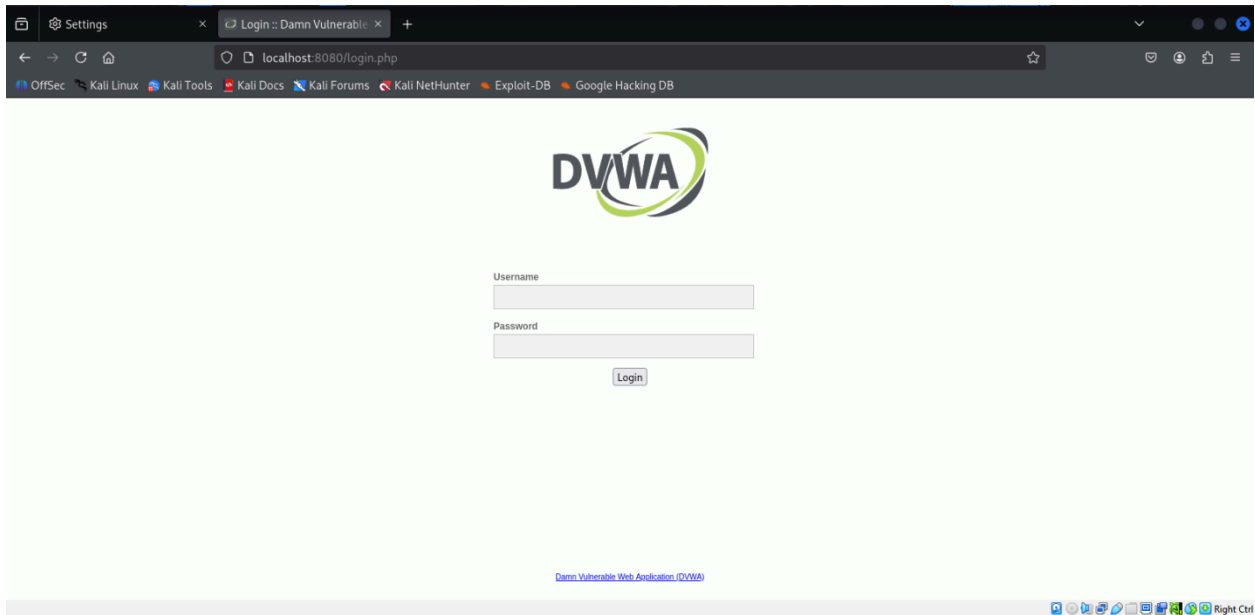
```

Access dvwa in Browser

- ❖ In kali open you firefox browser and type `http://localhost:8080`



- ❖ It direct us to the login page of DVWA vulnerable website



- ❖ Login with username:admin and password:password



- ❖ It direct to us now on the database setup page to create a database



Setup DVWA

Instructions

About

Database Setup

Click on the 'Create / Reset Database' button below to create or reset your database.
If you get an error make sure you have the correct user credentials in: `/var/www/html/DVWA/config/config.inc.php`

If the database already exists, **it will be cleared and the data will be reset.**
You can also use this to reset the administrator credentials ("**admin** // **password**") at any stage.

Setup Check

General

Operating system: ***nix**

DVWA version:

- Git reference: **461b83ad590e55a0a8af4d512564d5feb8678c9b**
- Author: Robin Wood

reCAPTCHA key: **Missing**

Writable folder `/var/www/html/DVWA/hackable/uploads/`: **Yes**
Writable folder `/var/www/html/DVWA/config/`: **Yes**

Apache

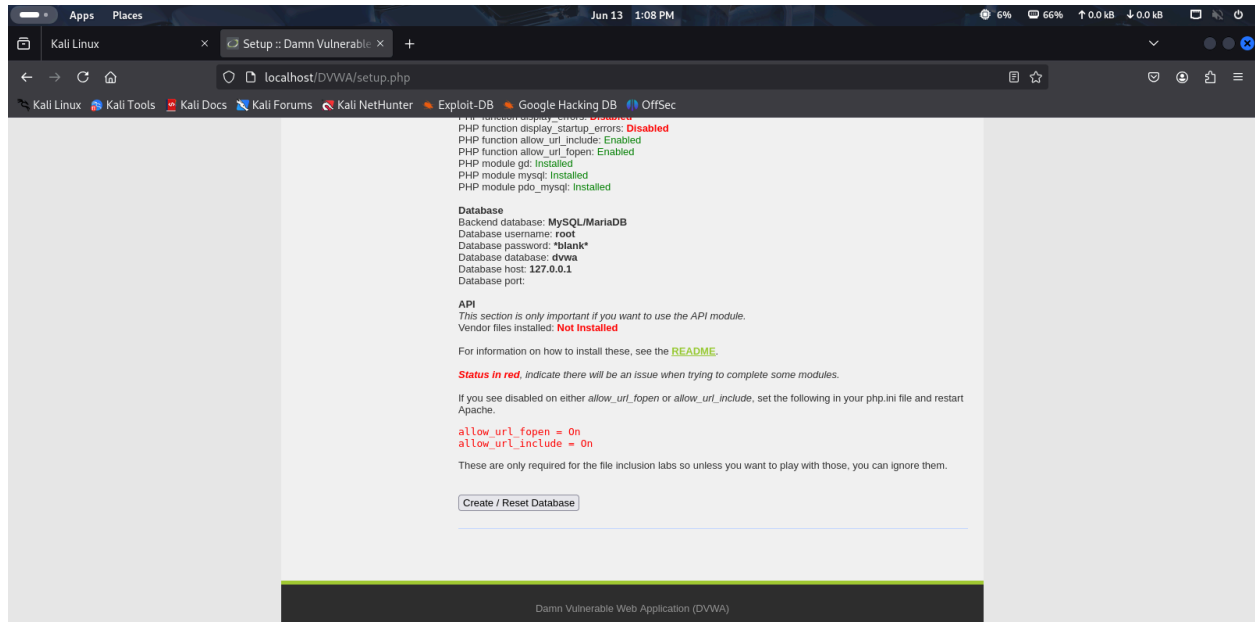
Web Server `SERVER_NAME`: **localhost**

`mod_rewrite`: **Not Enabled**
`mod_rewrite` is required for the AP labs.

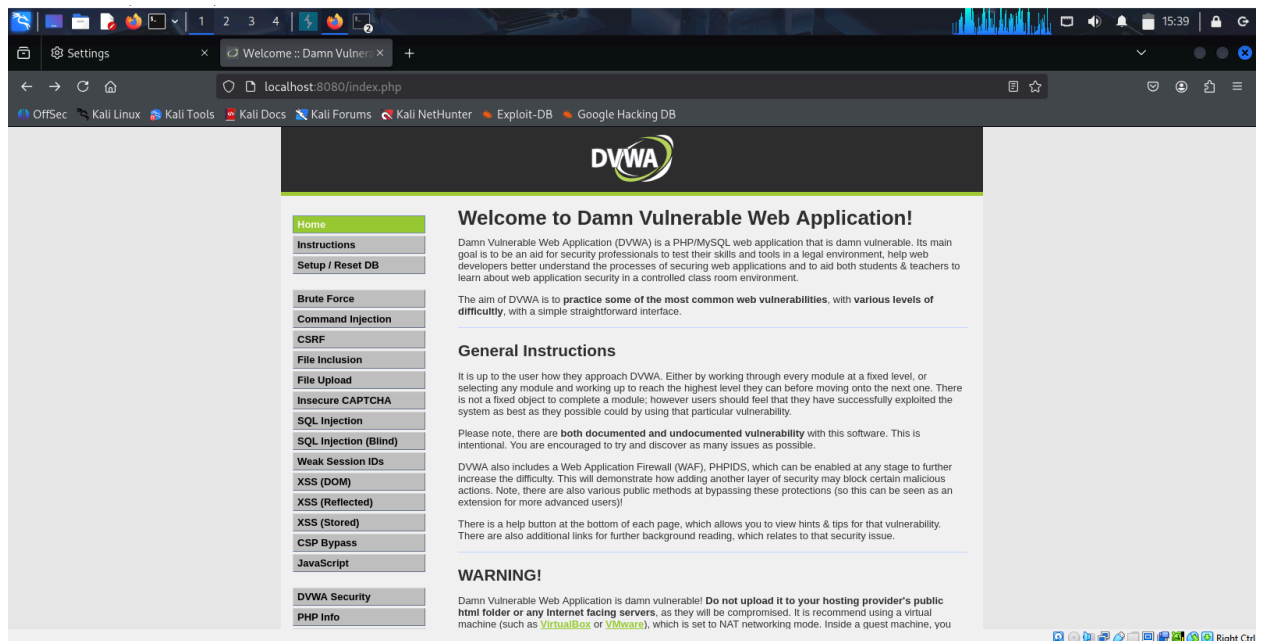
PHP

PHP version: **8.4.6**
PHP function `display_errors`: **Disabled**
PHP function `display_startup_errors`: **Disabled**

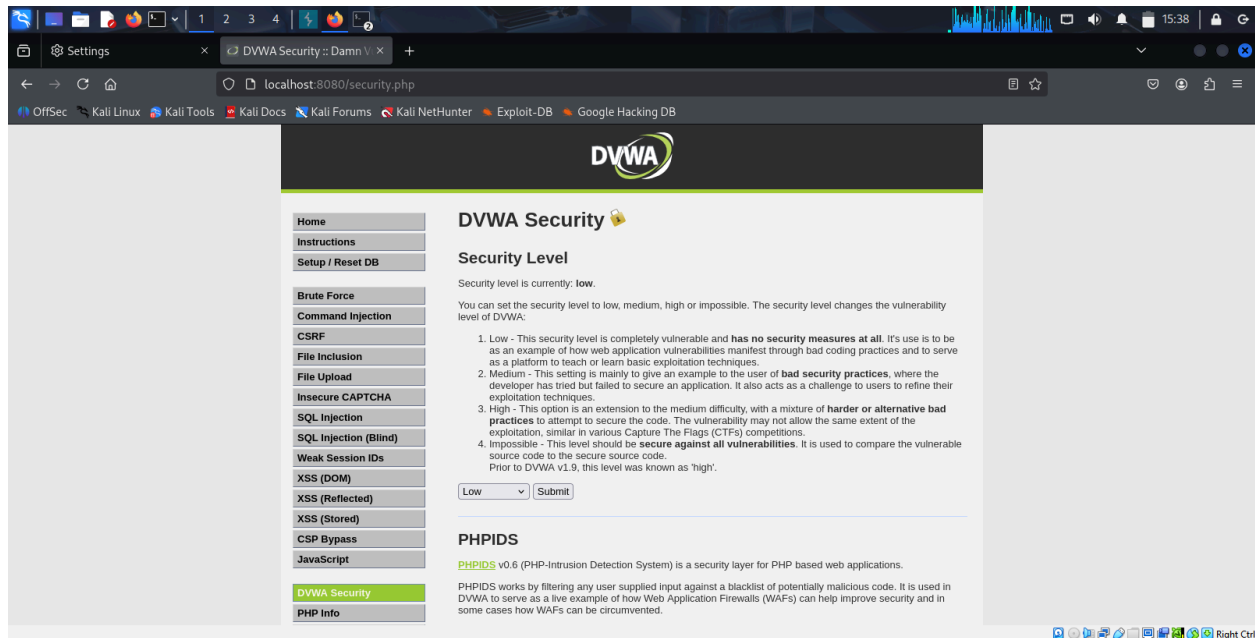
❖ Click create / reset database



❖ Then it direct us to the DAMN Vulnerable application

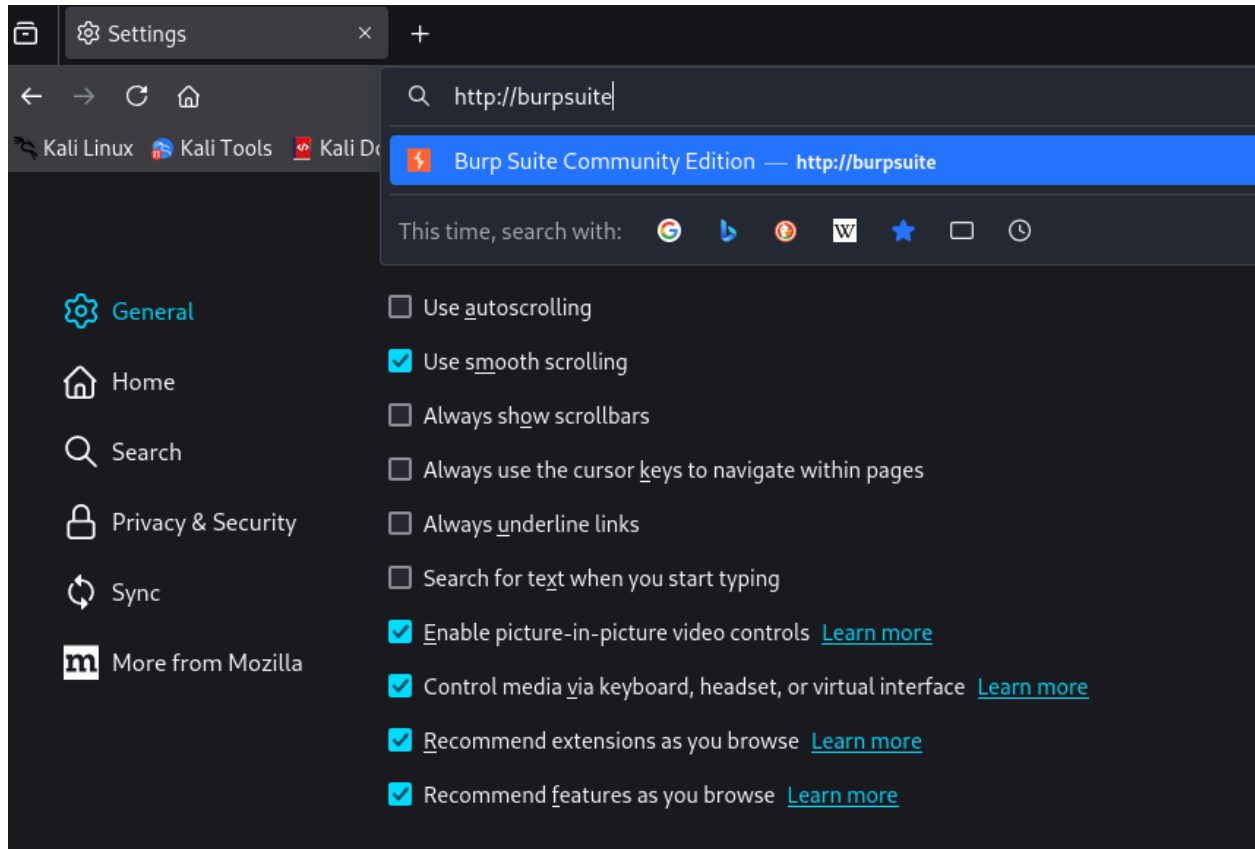


❖ Click DVWA security and set it low and click submit button

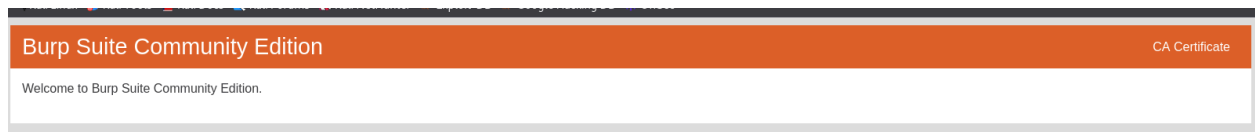


Installation of certificate of Burp Suite

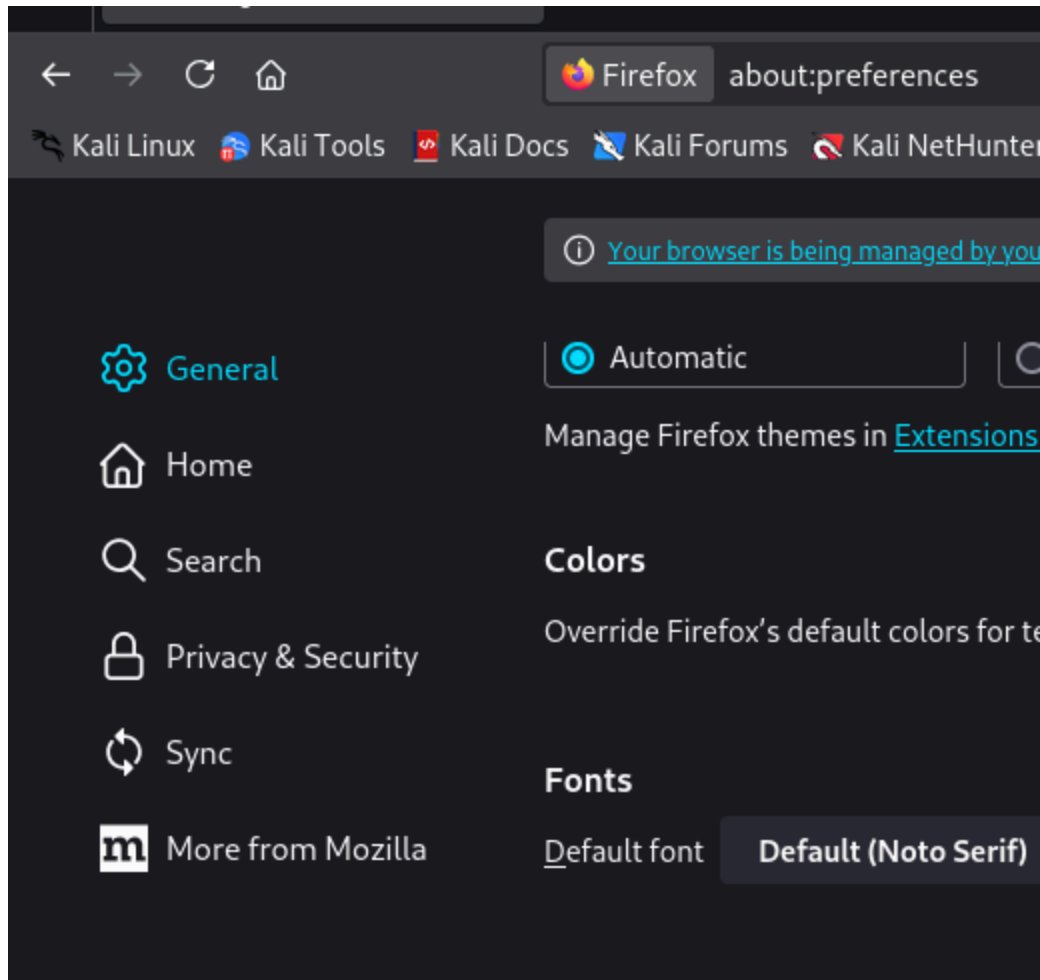
- ❖ To install certificate we have to instal burp certiccate through <http://burpsuite>



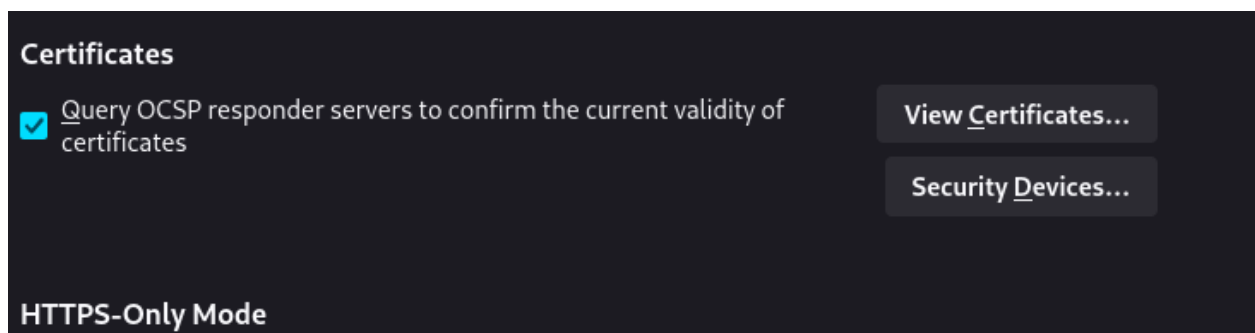
❖ Click on the right corner on CA Certificate



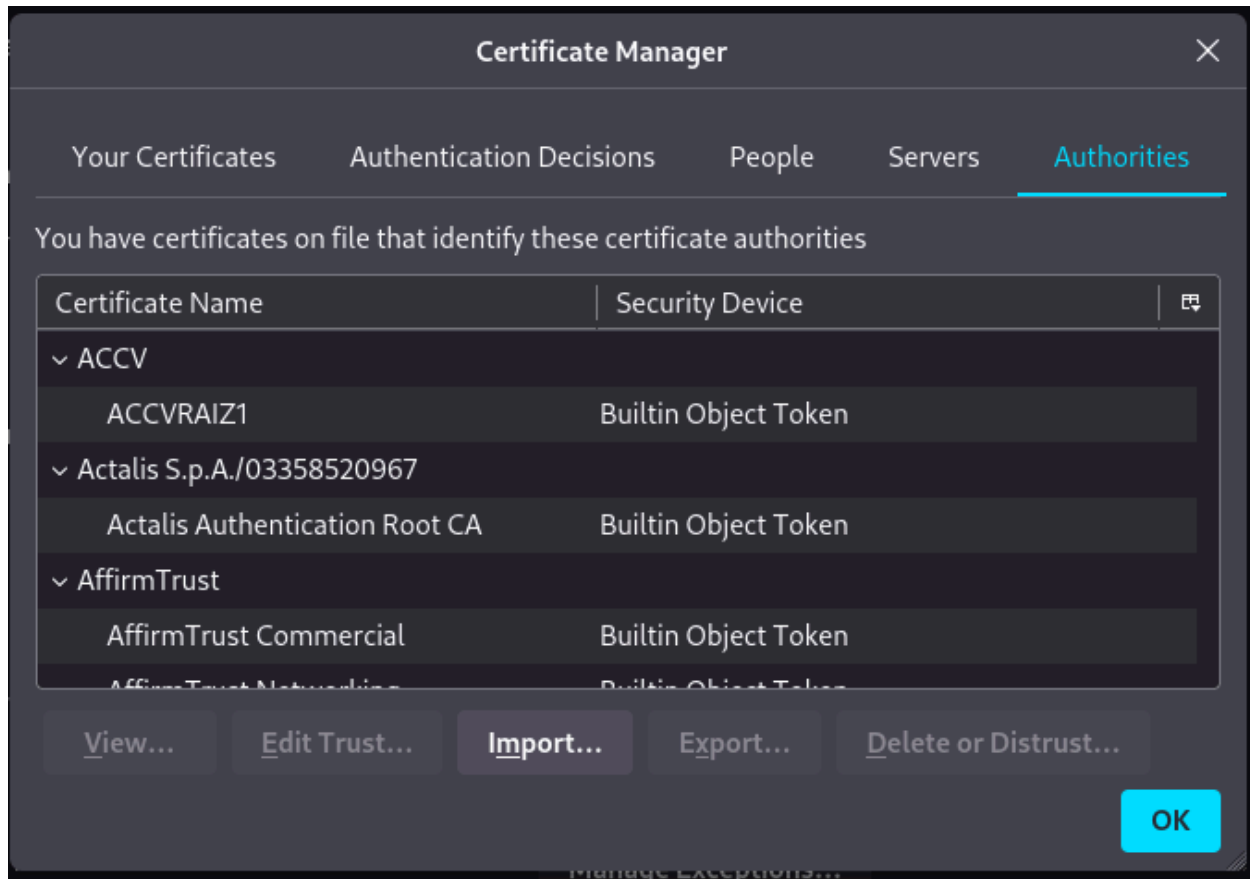
❖ Open new browser and open about:preferences



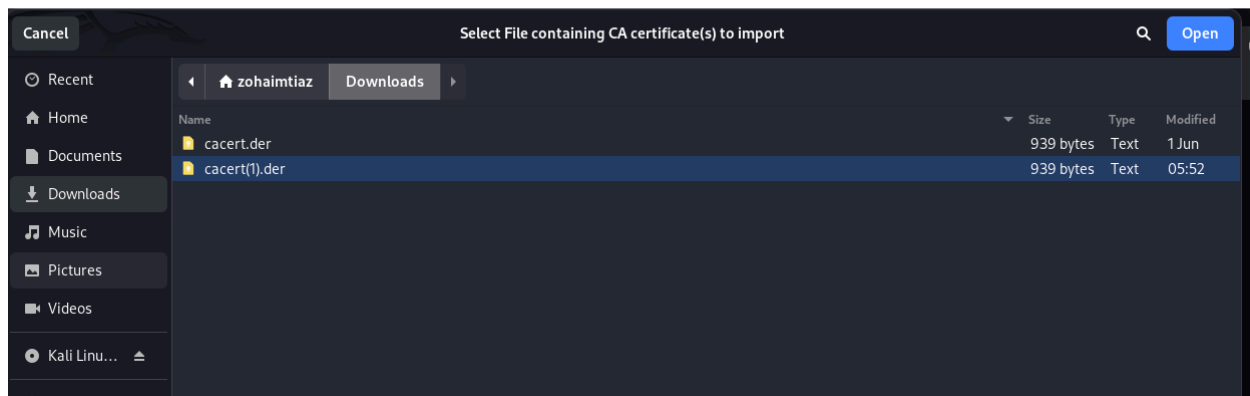
- ❖ Go to the privacy security and then click view certificate



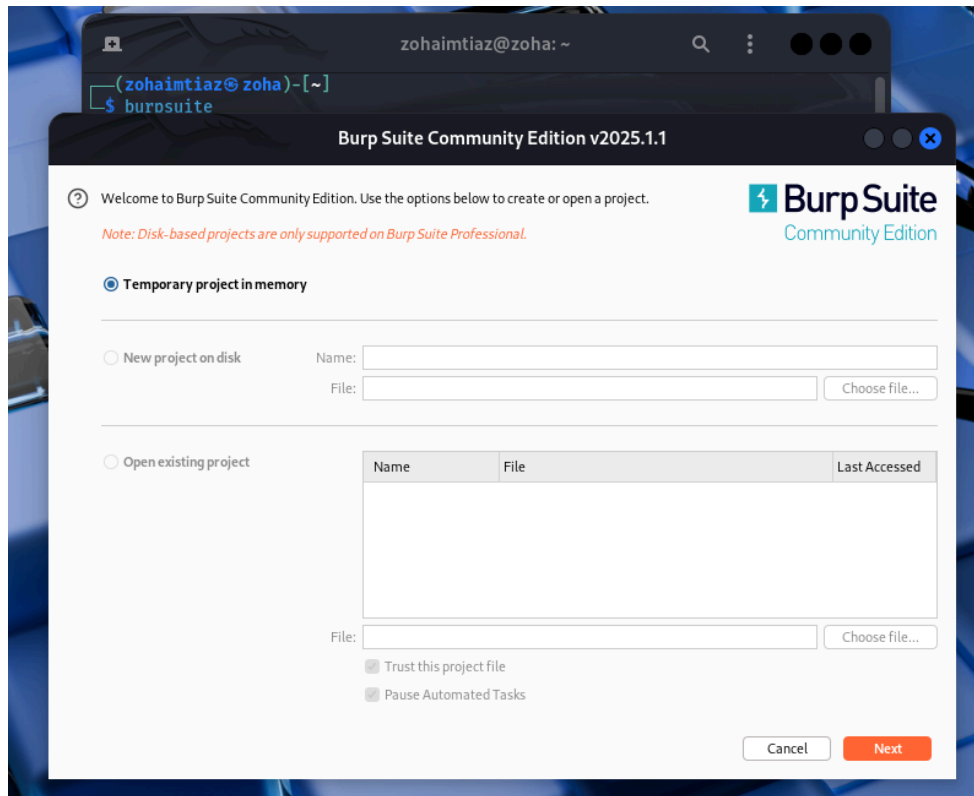
- ❖ Import certificate now



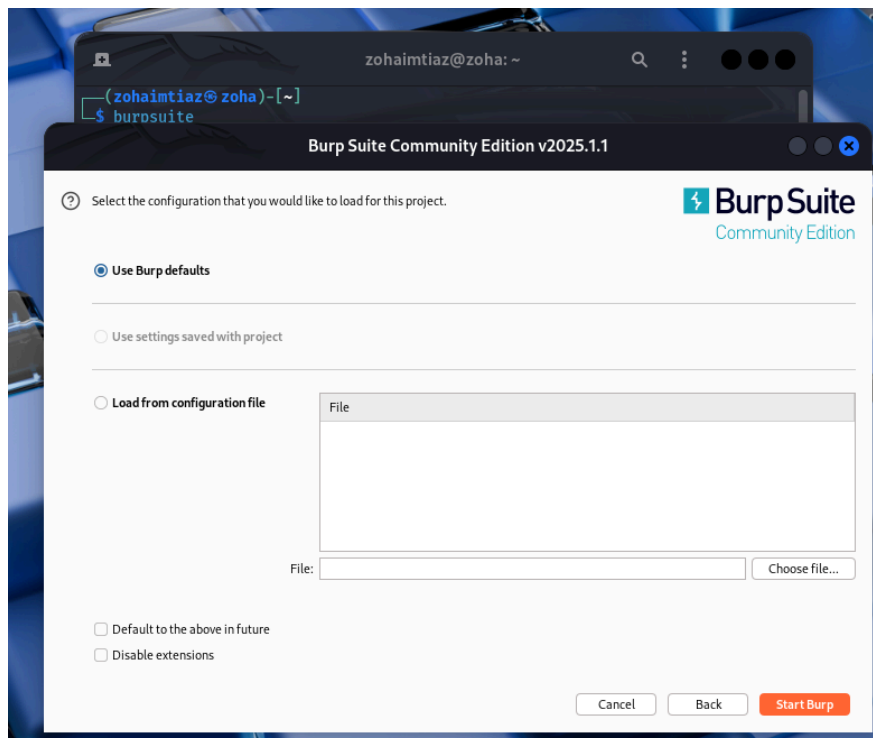
- ❖ Select the download certificate and click open on right corner



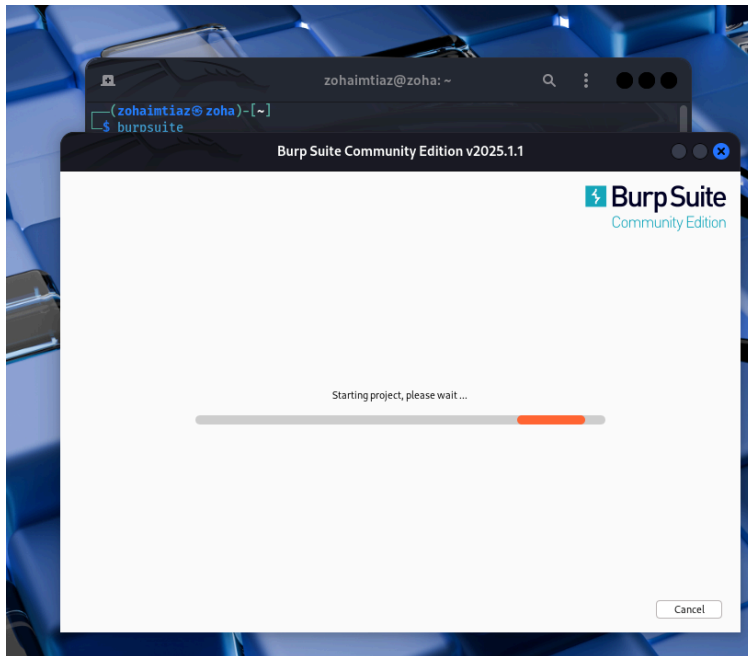
- ❖ Now write command on terminal burpsuite to open tool and the temporary project in memory click next.



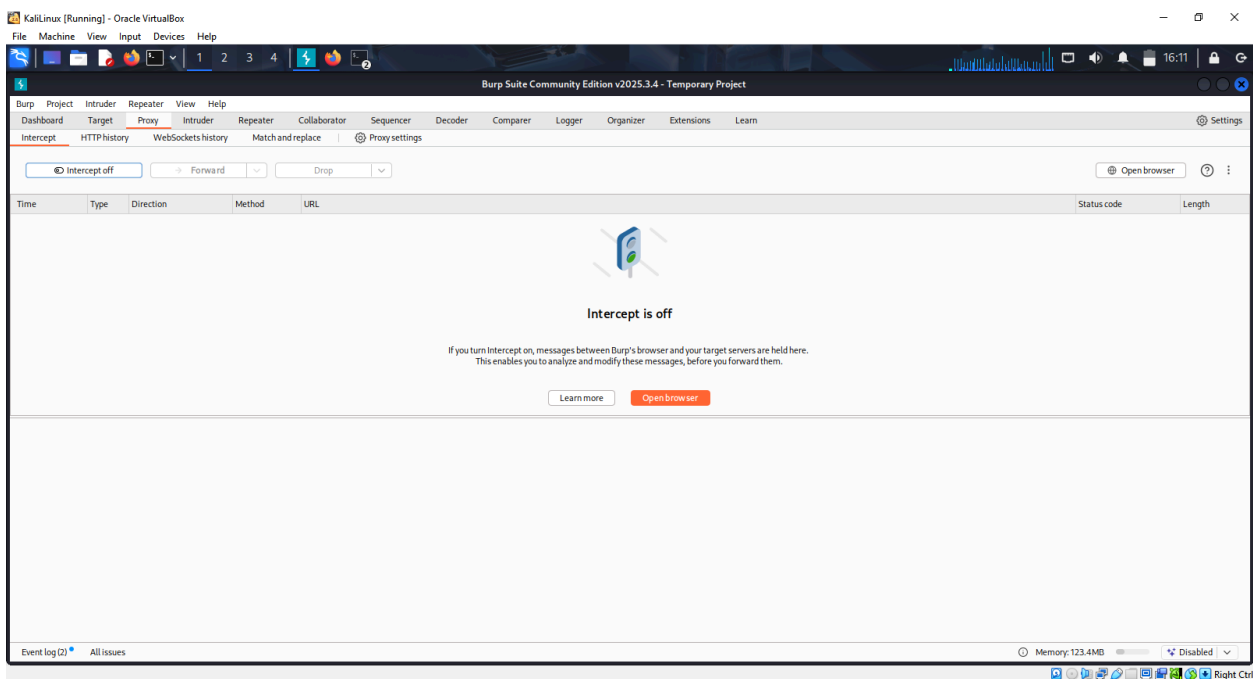
❖ Now click on start burp



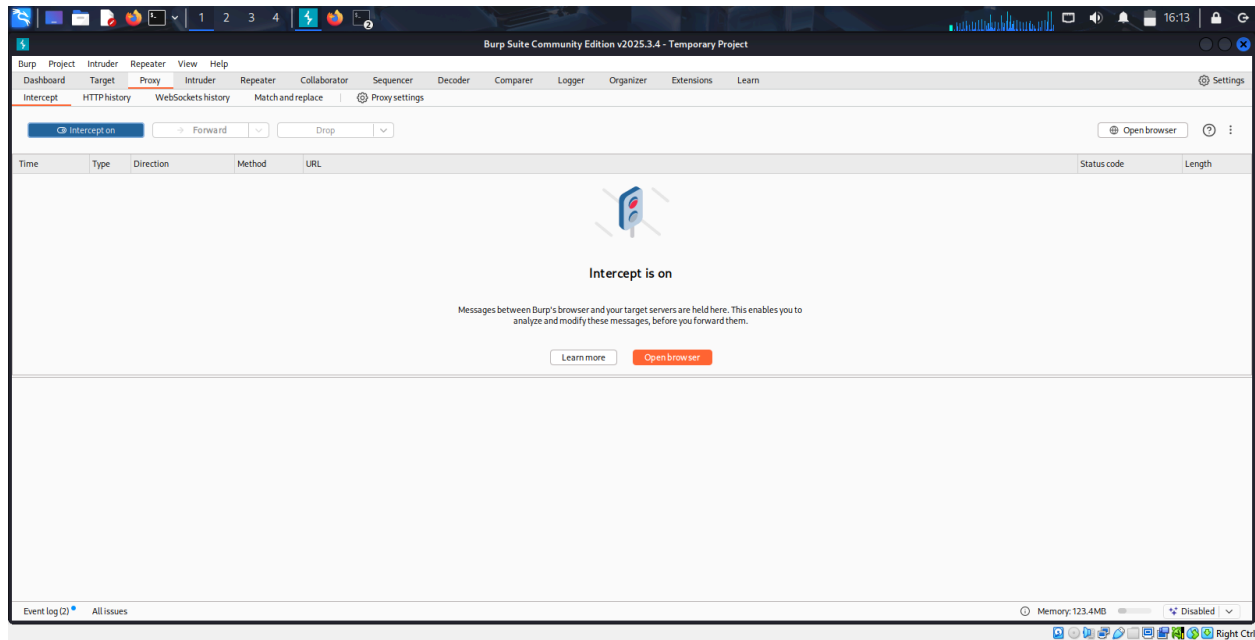
- ❖ It takes some time to load



- ❖ As you see the intercept is off



- ❖ Go to proxy intercept and click to on the intercept

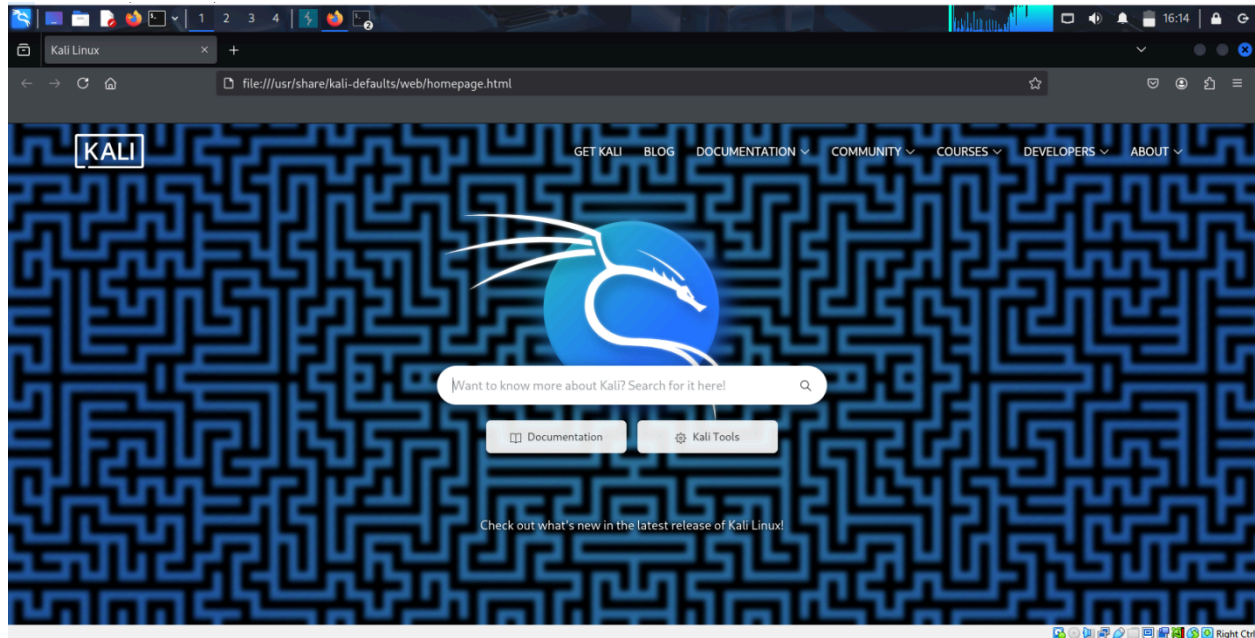


Browser Settings

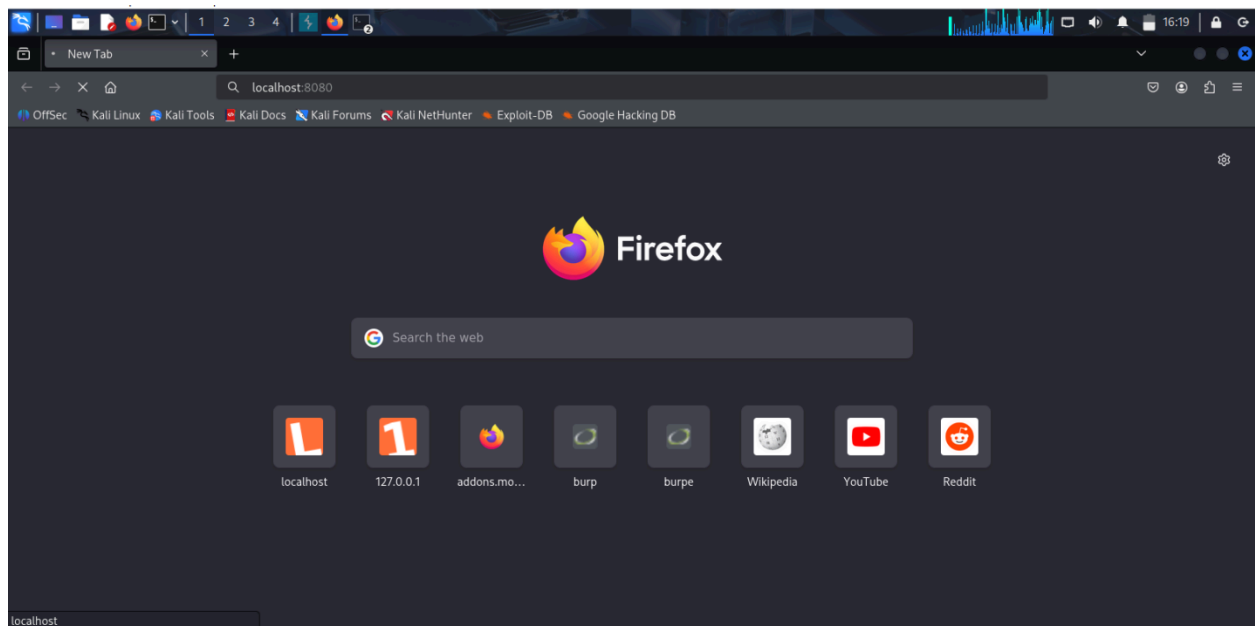
❖ Now we have to work on the browser click firefox browser



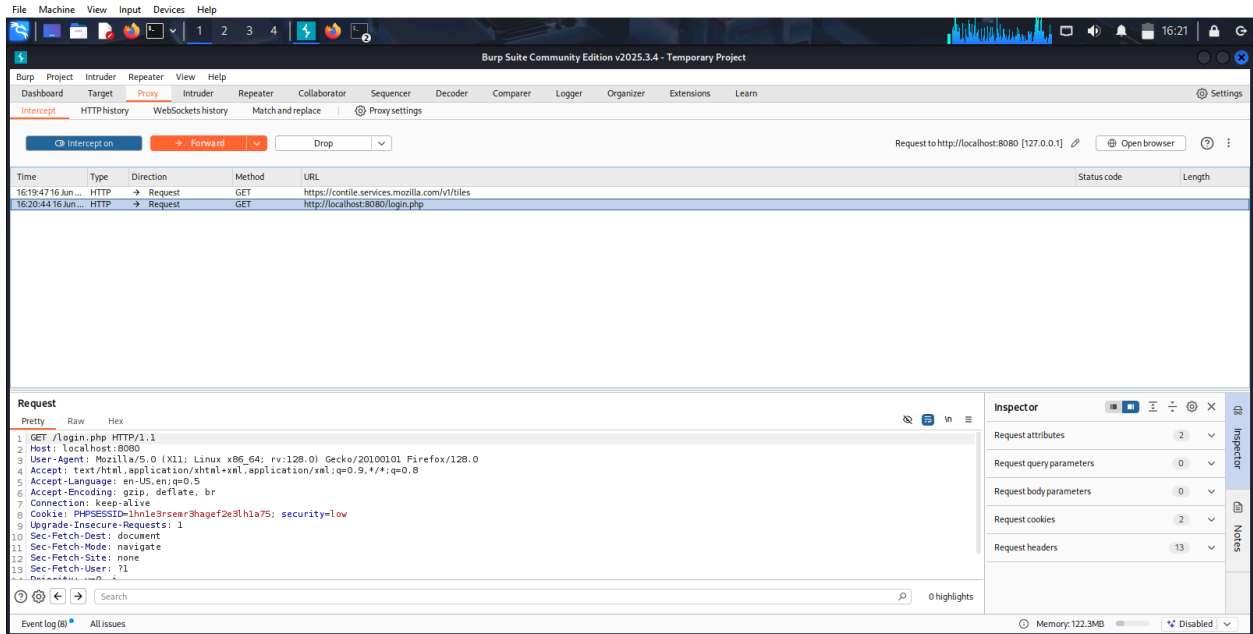
❖ Here you see the browser is open



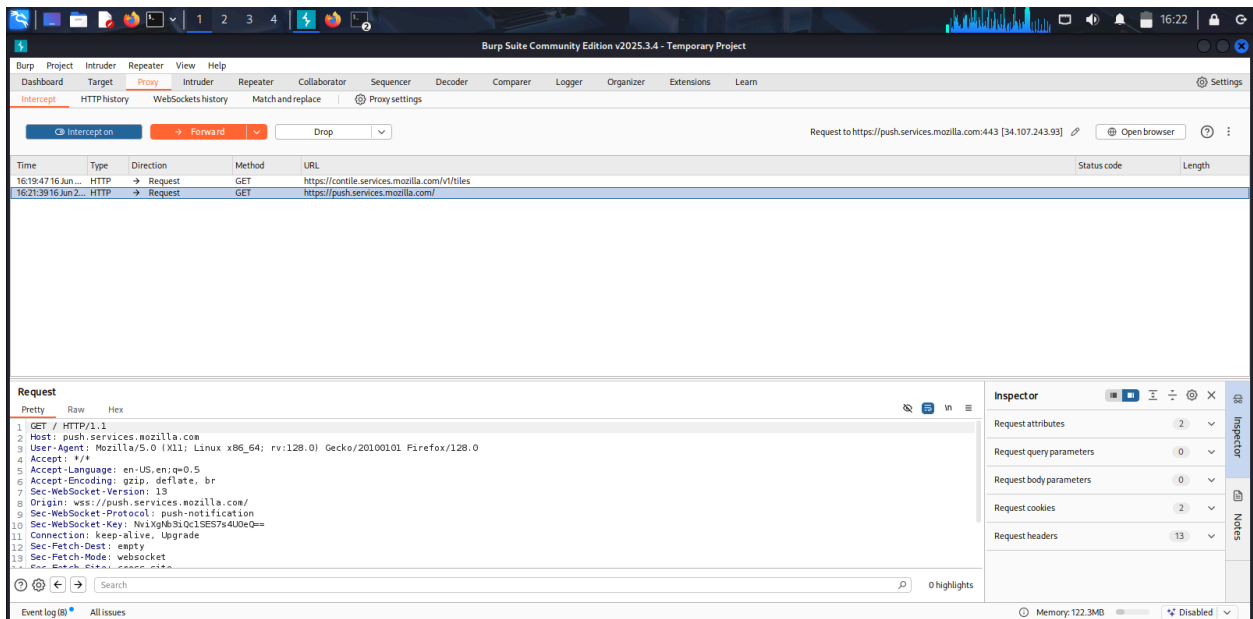
❖ Click new tab and write http://localhost:8080



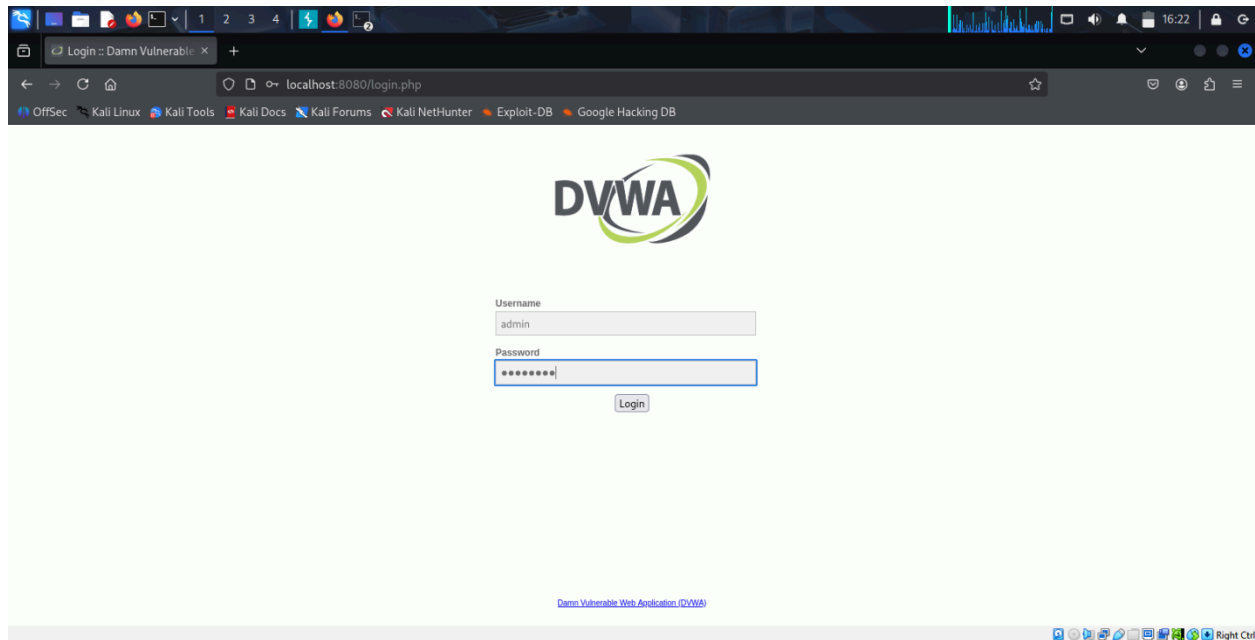
❖ As you see the burp suite intercept the request and shw here as login.php



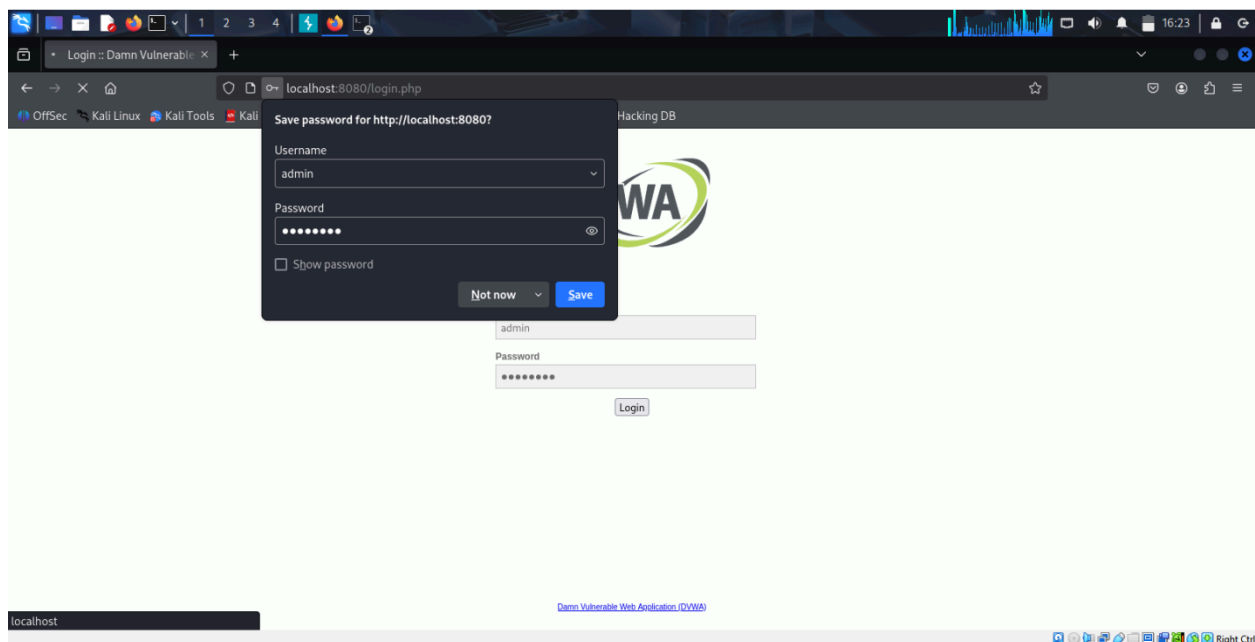
❖ Now here you see the forward button click on it



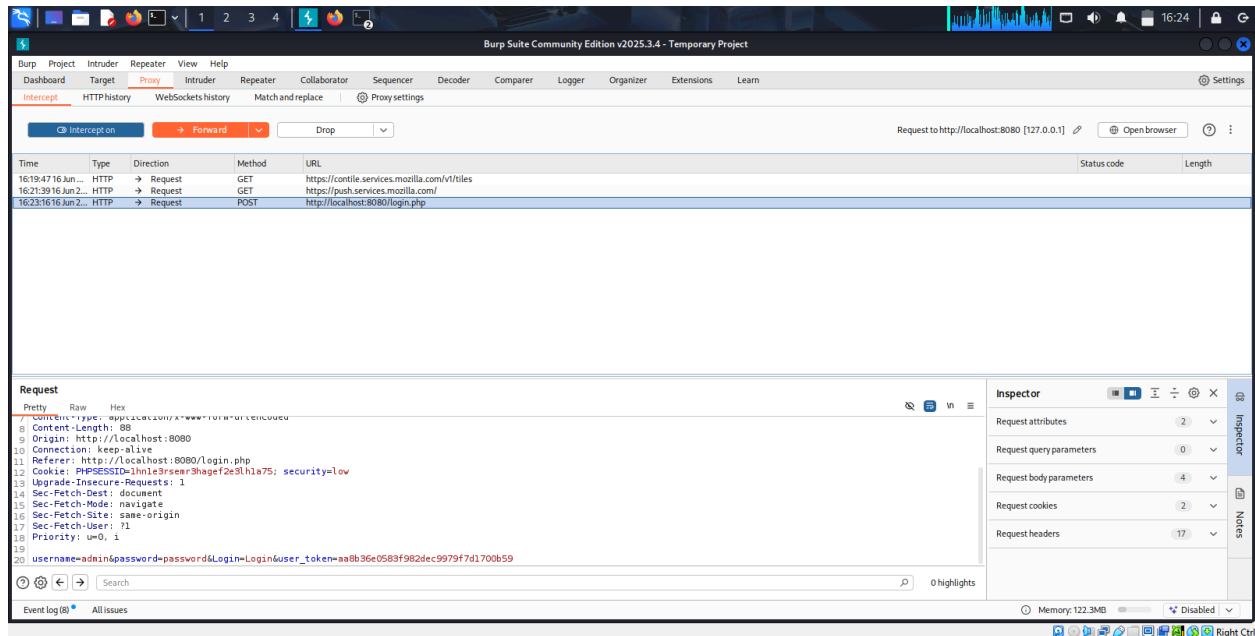
❖ After clicking it open browser again



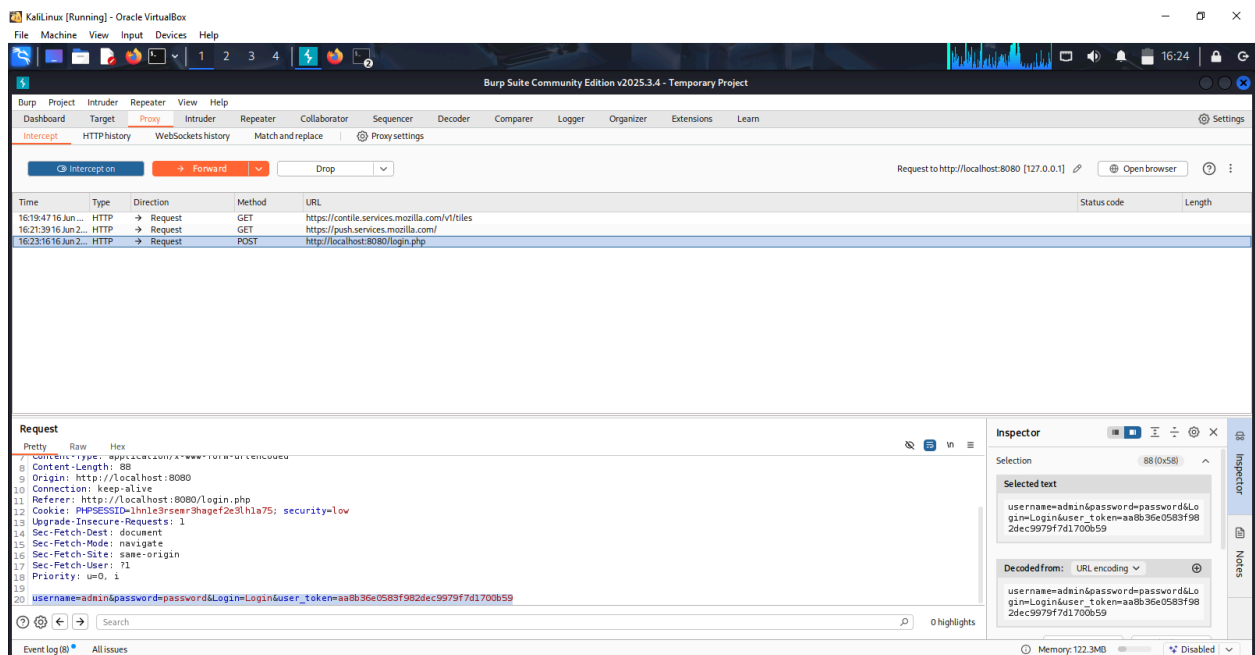
- ❖ Add username and password



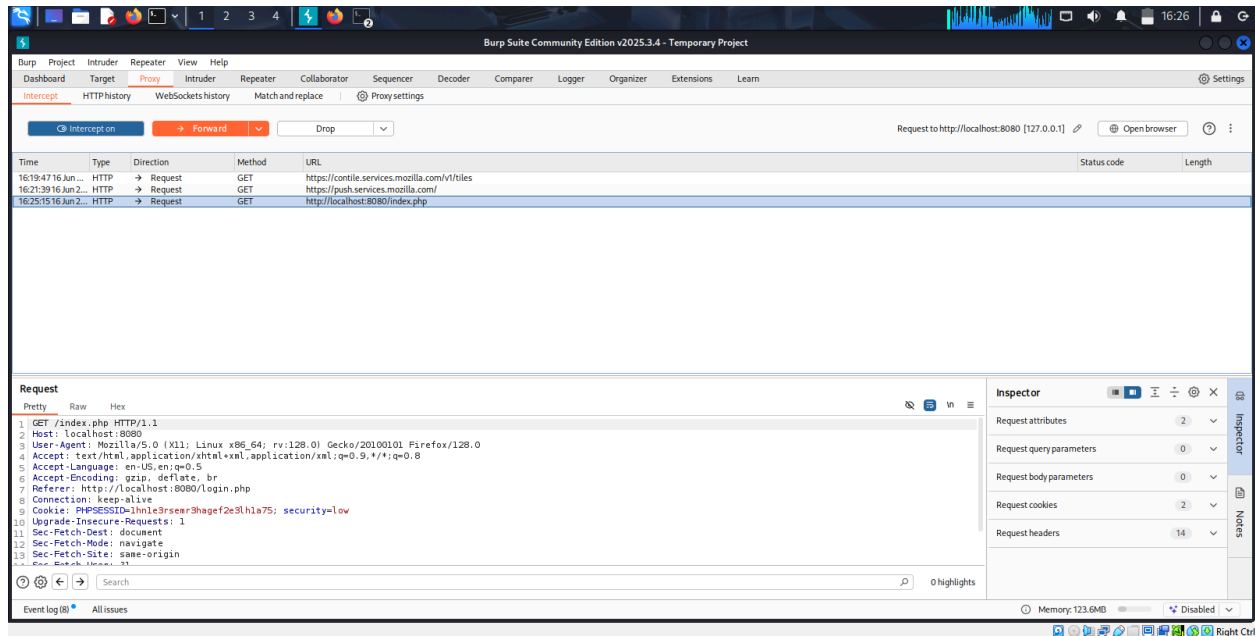
- ❖ As you see the request intercept and it and in the request session you see the admin and password



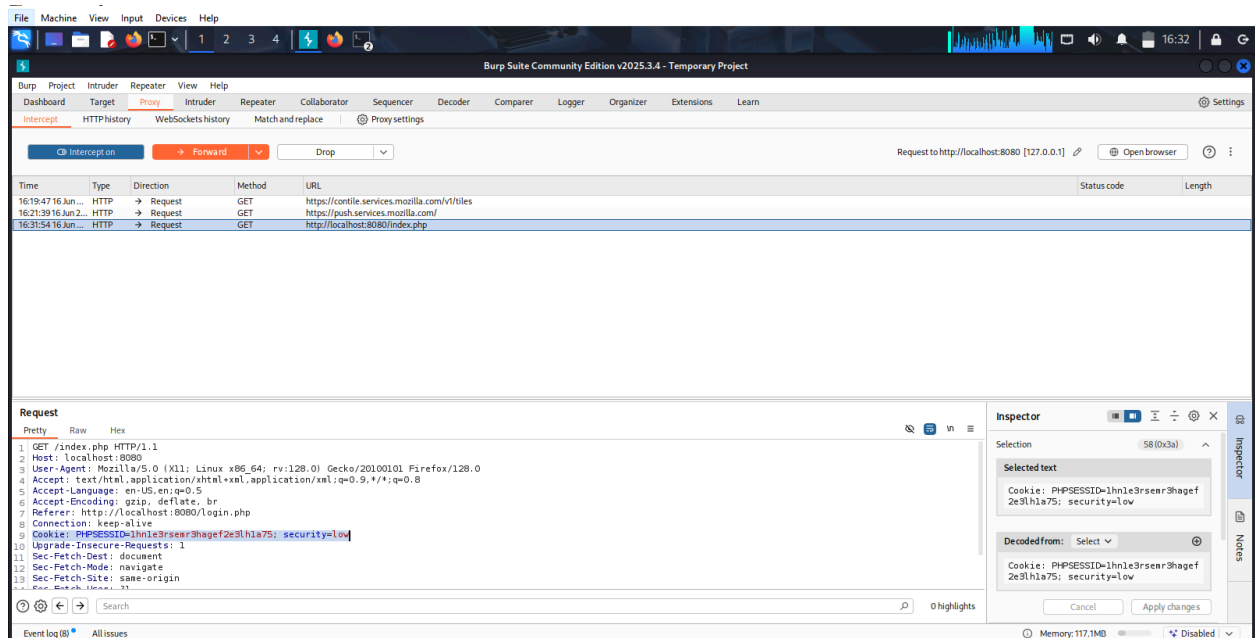
❖ As I highlight here and when you forward this request it automatically capture index.php file



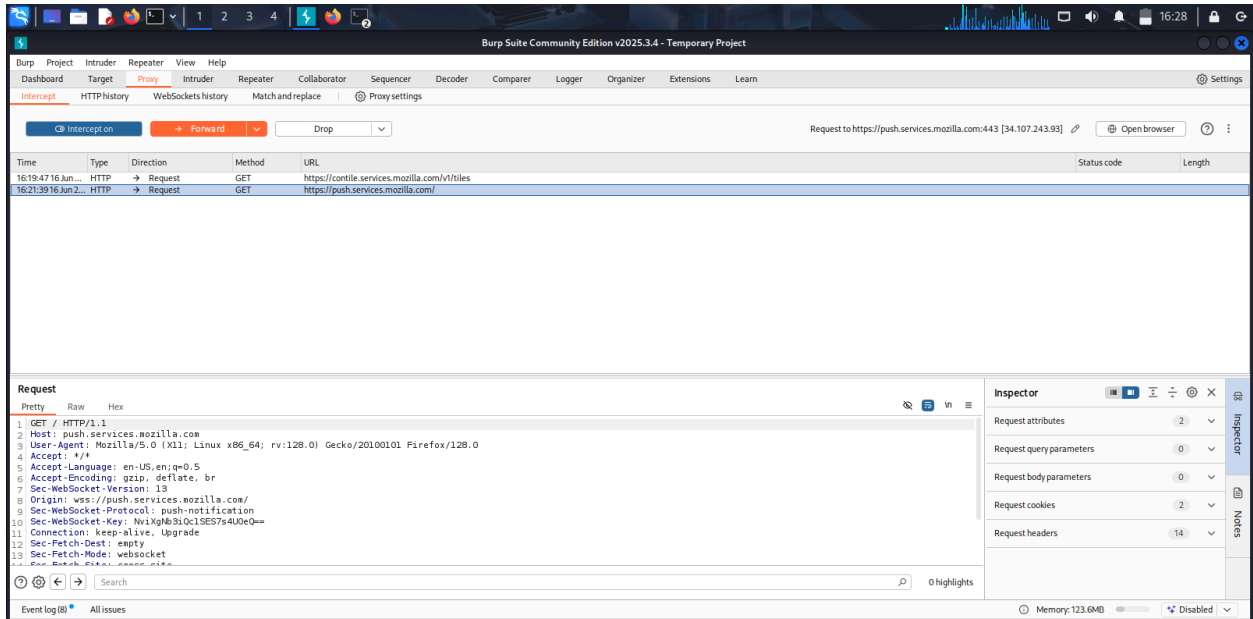
❖ Here you see the request is forwarded and capture the index page



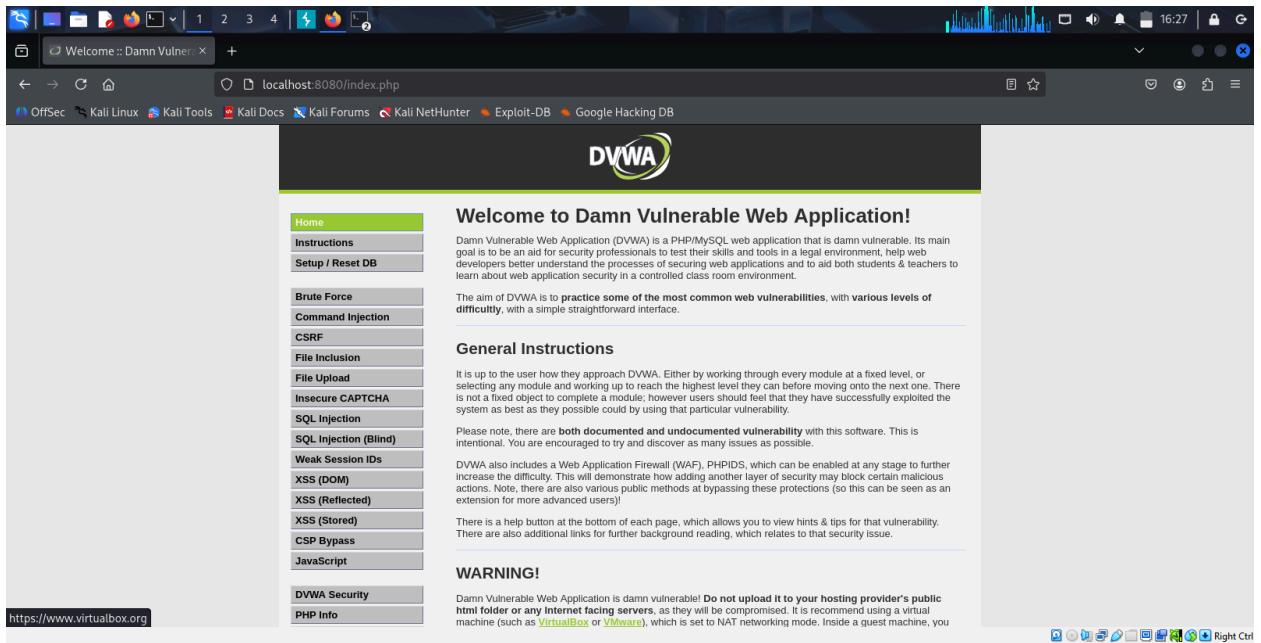
❖ Here you see the the index.php loaded and here you see session id means cookie



❖ Here we forward the request



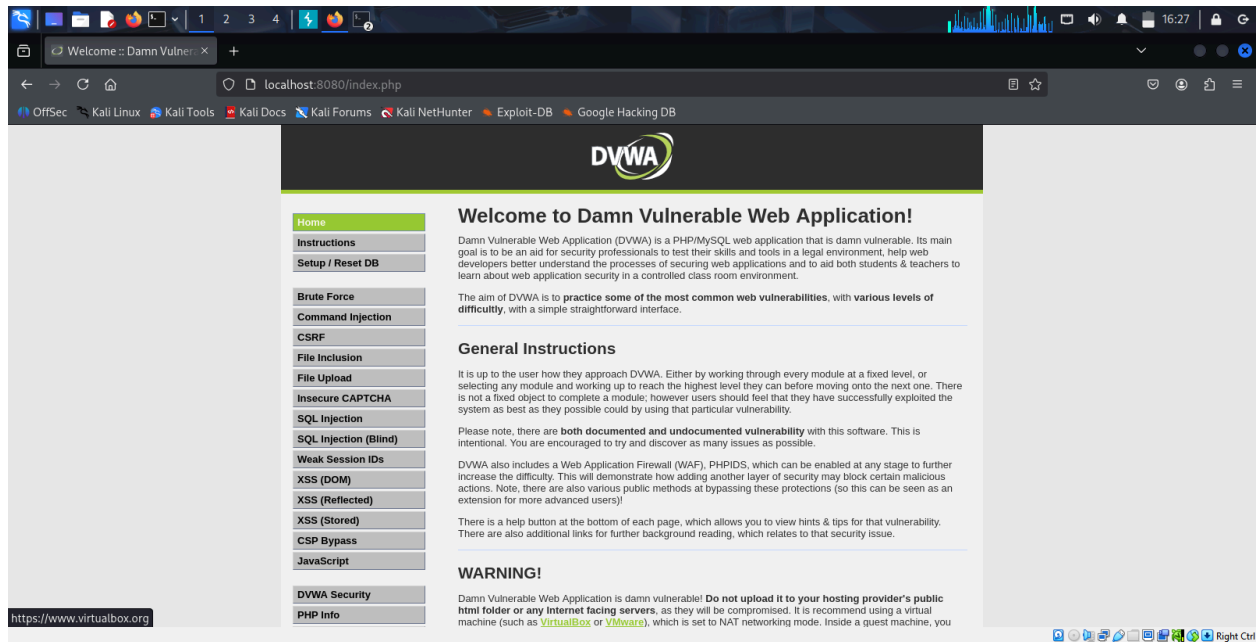
❖ And as you see the DAMN webpage here



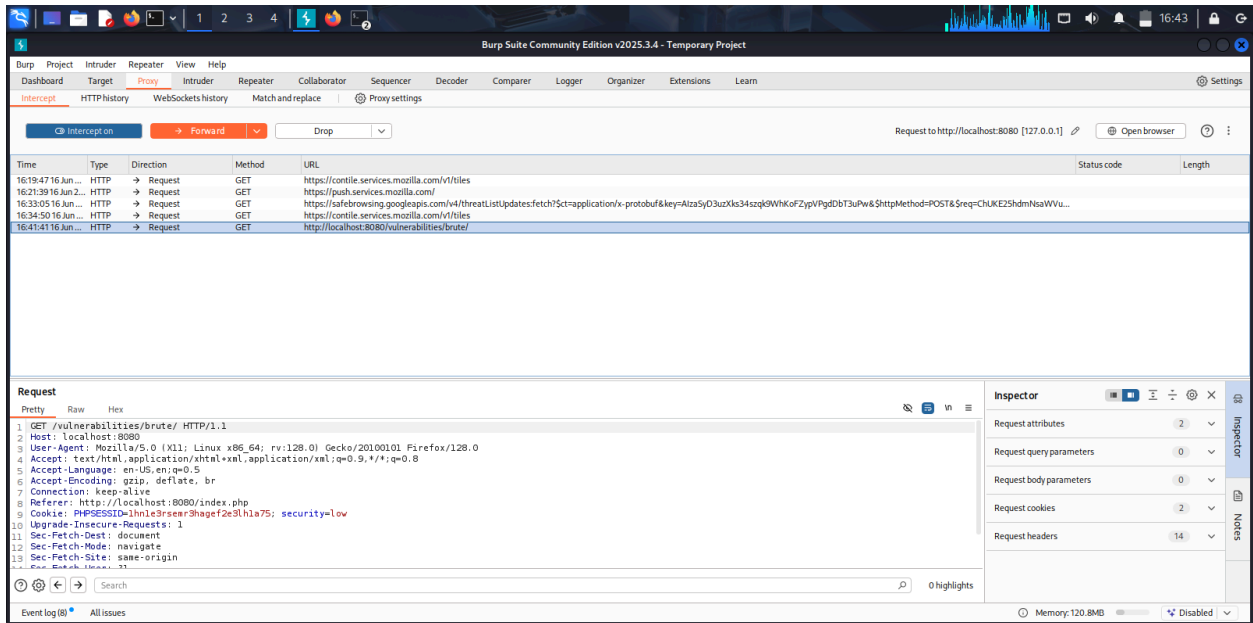
Use Cases 1:

Brute force Attack

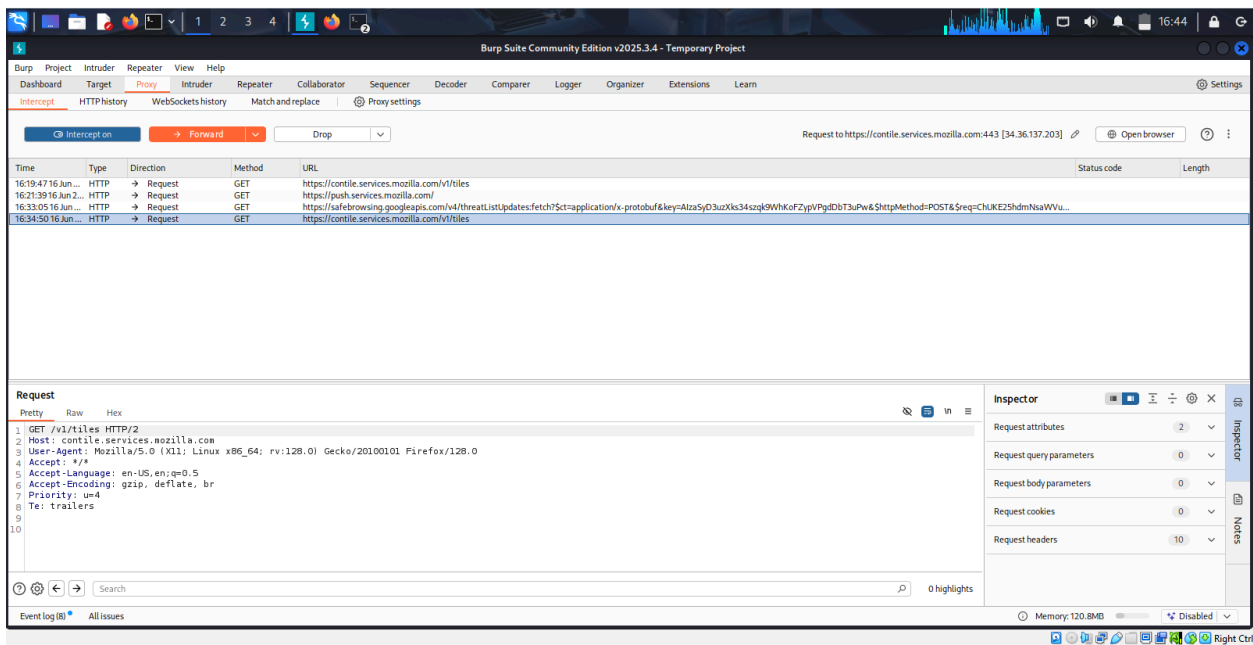
- ❖ Now click on brute force at the left column



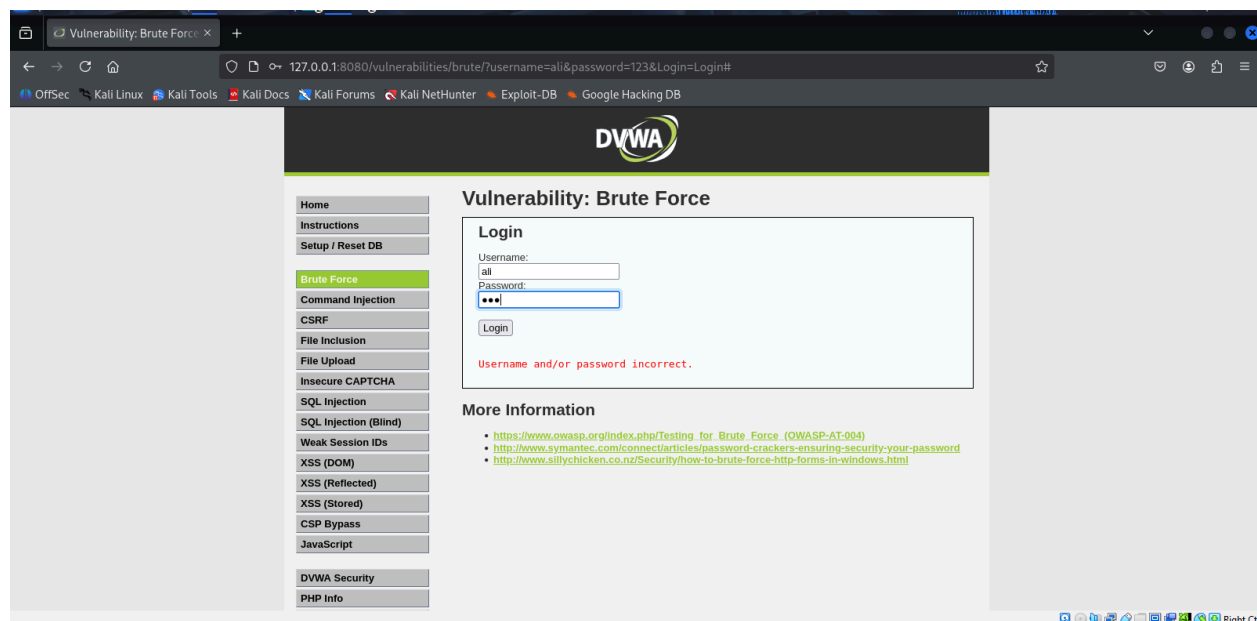
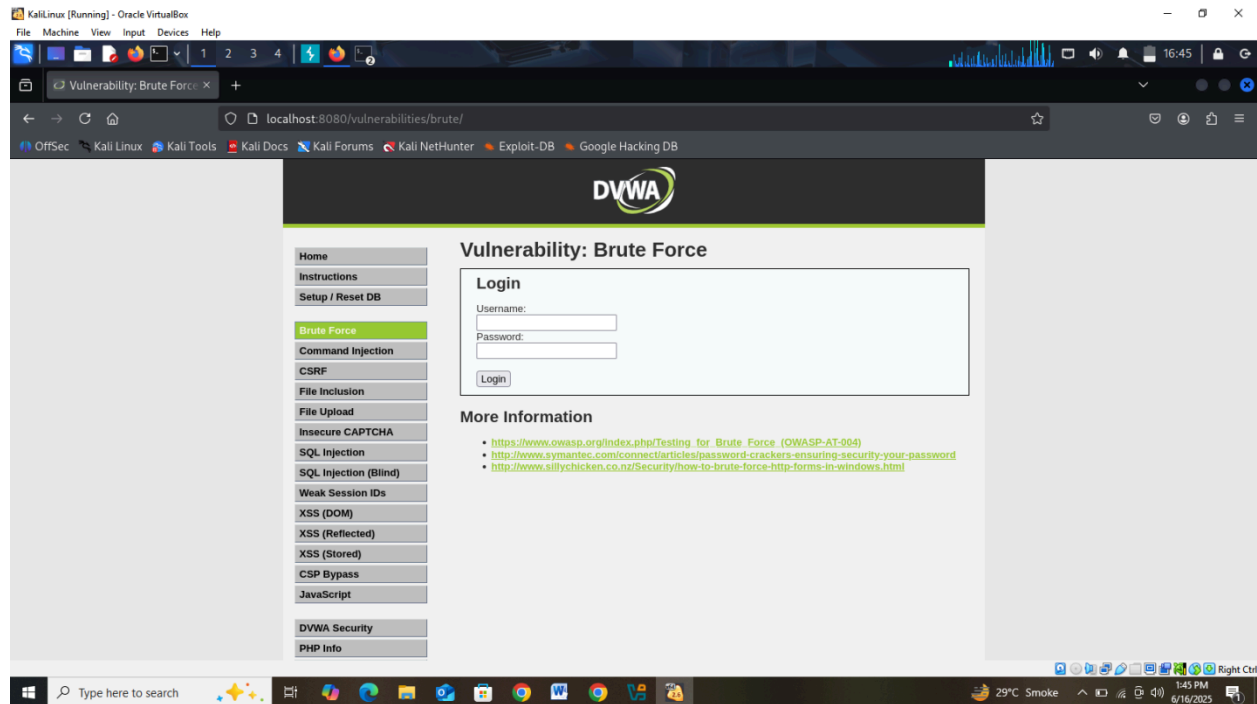
- ❖ When you click on brute force the burp capture the request and page will not loaded until unless we click on forward



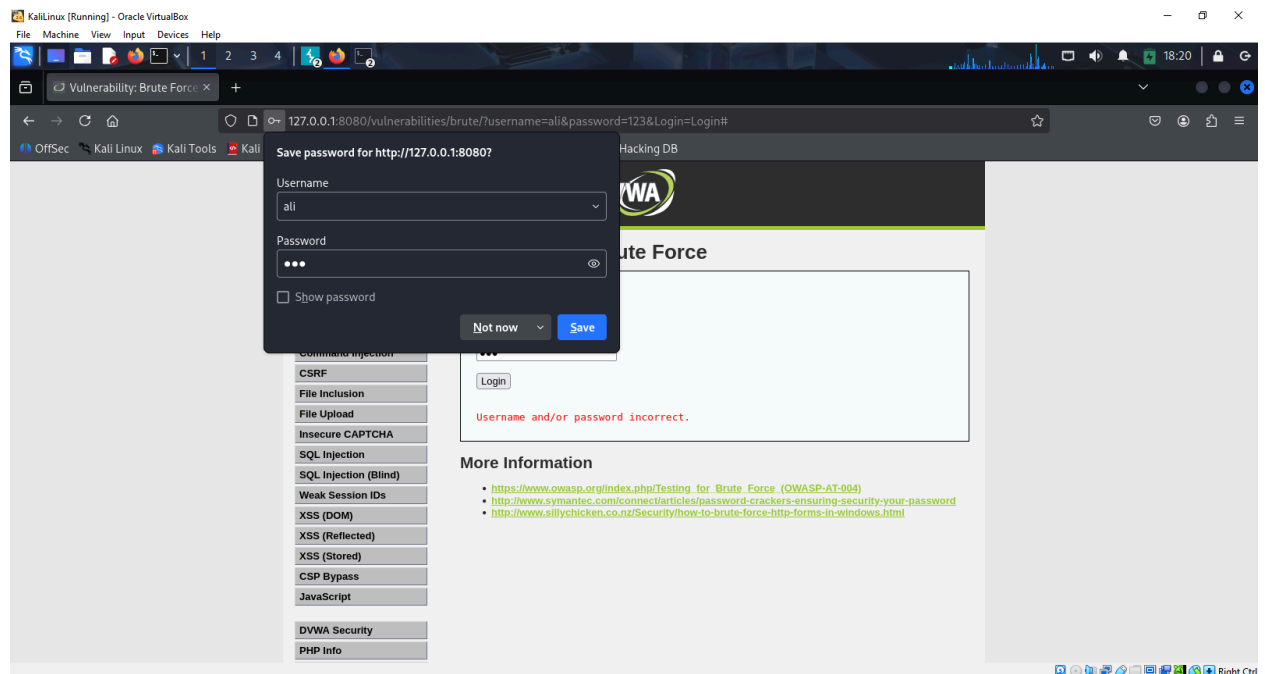
❖ Here we forward the request so we load our page



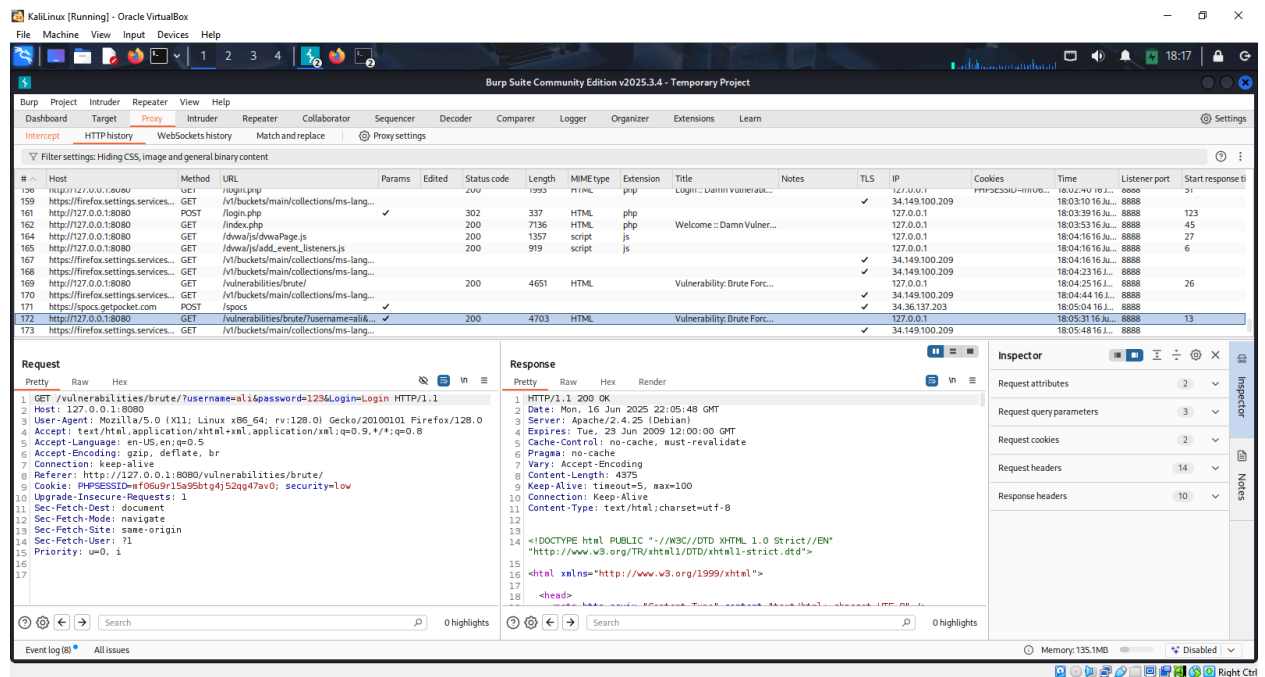
❖ As you see the page is loaded here with username and password



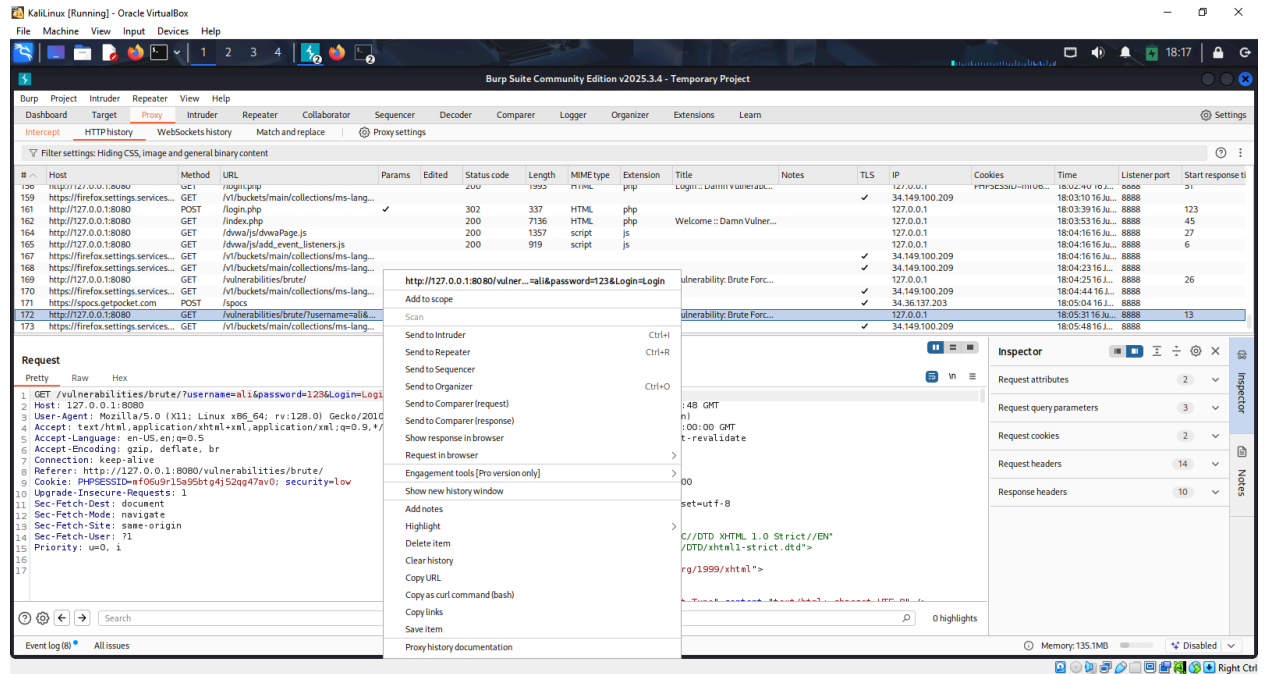
- ❖ Enter username Ali and password 123 and click login and you have to forward the request



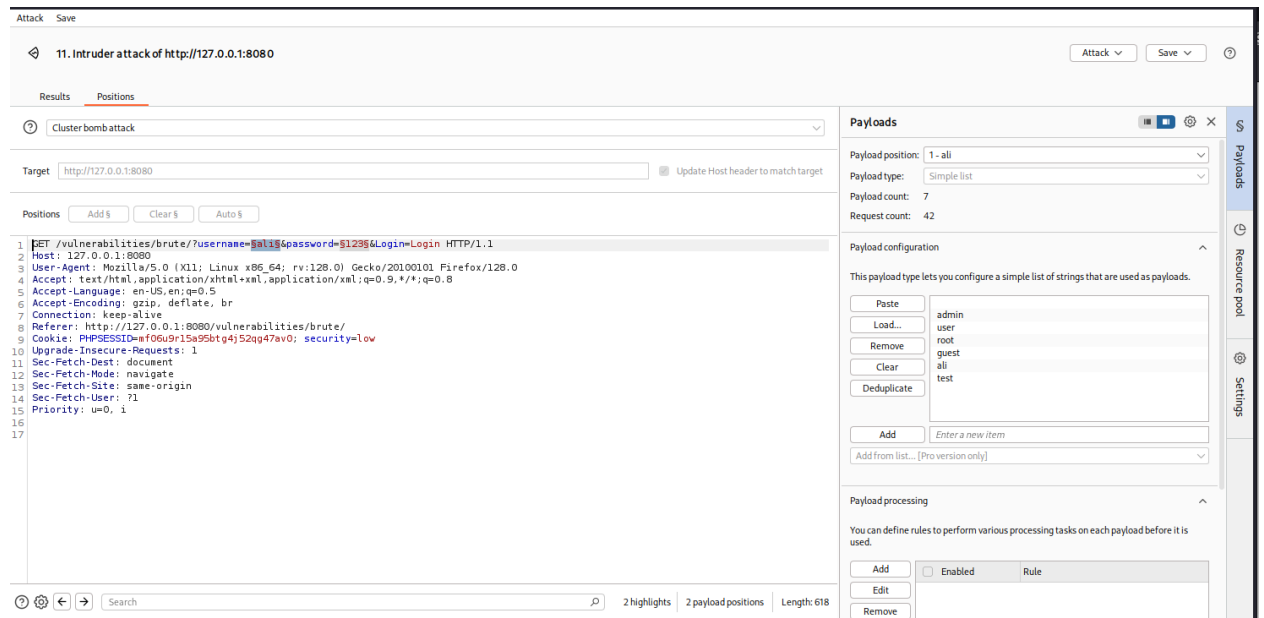
❖ Now go to the burp suite and click proxy then http history and see the request



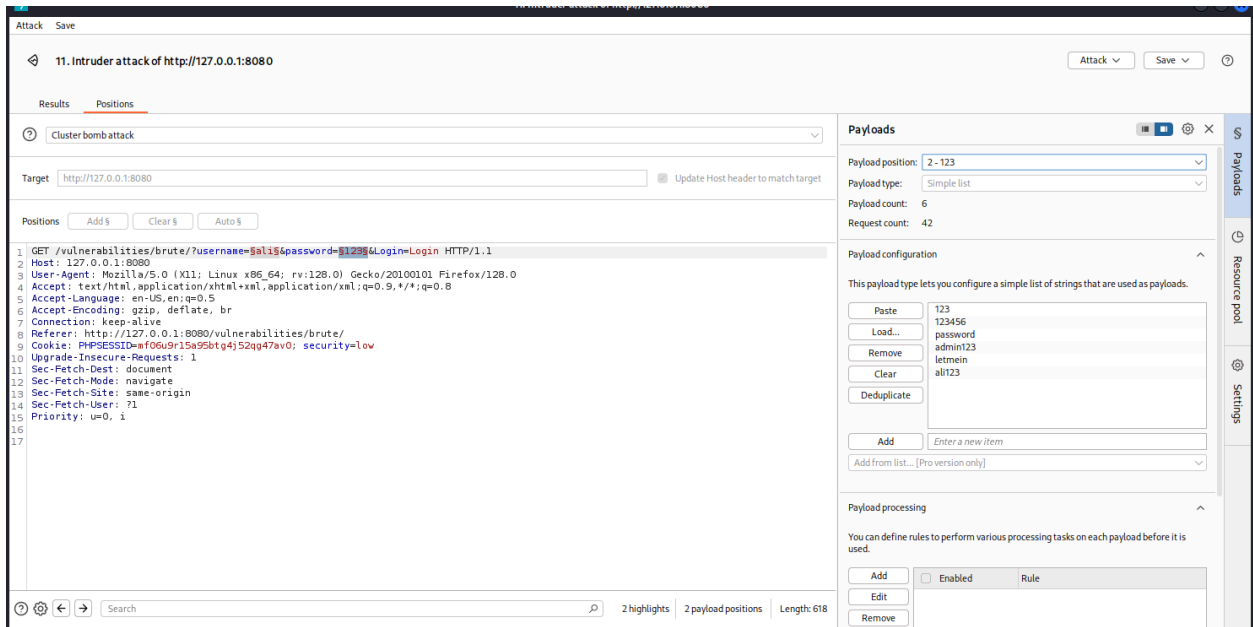
❖ See and right click on it and send to the intruder



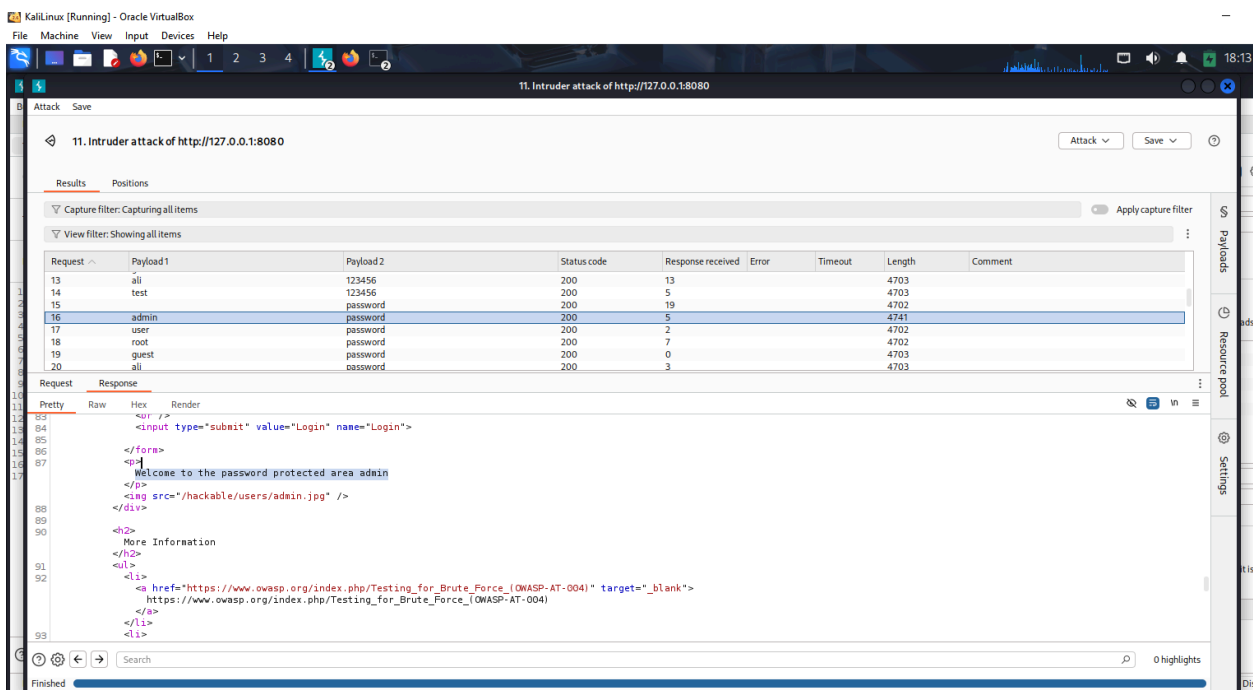
❖ Cluster bomb attack select the pay loads add the payload to to perform testing



❖ Here you see the second pay load position



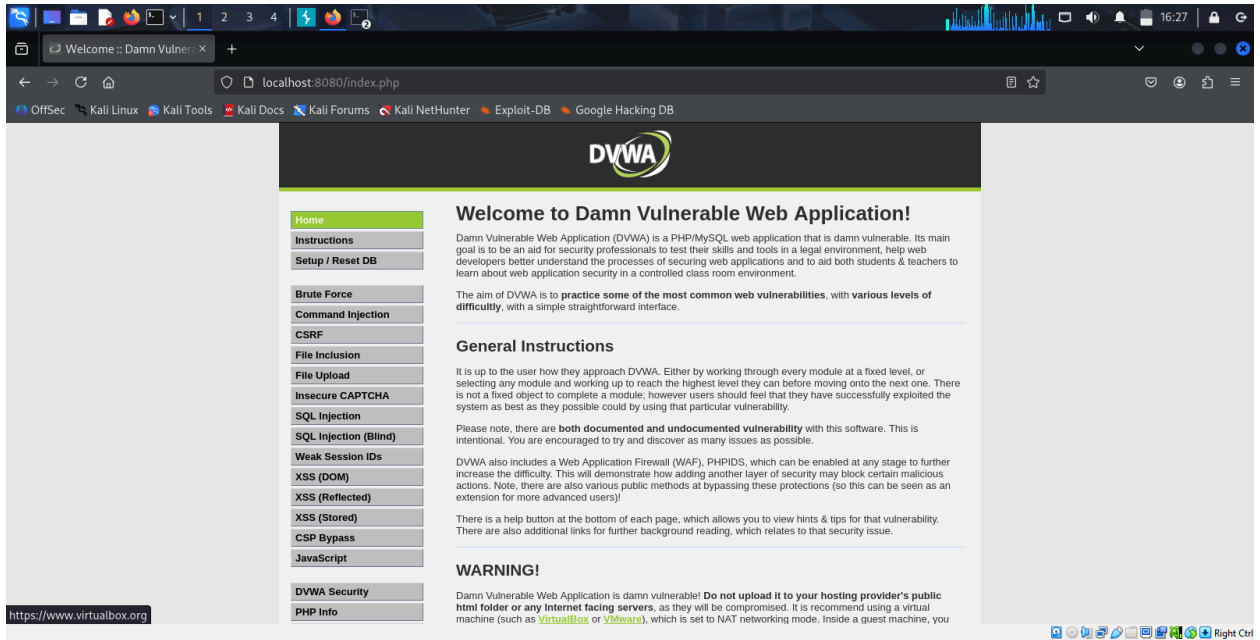
❖ Here you see the attack is successful **“Welcome to password protected area admin”**



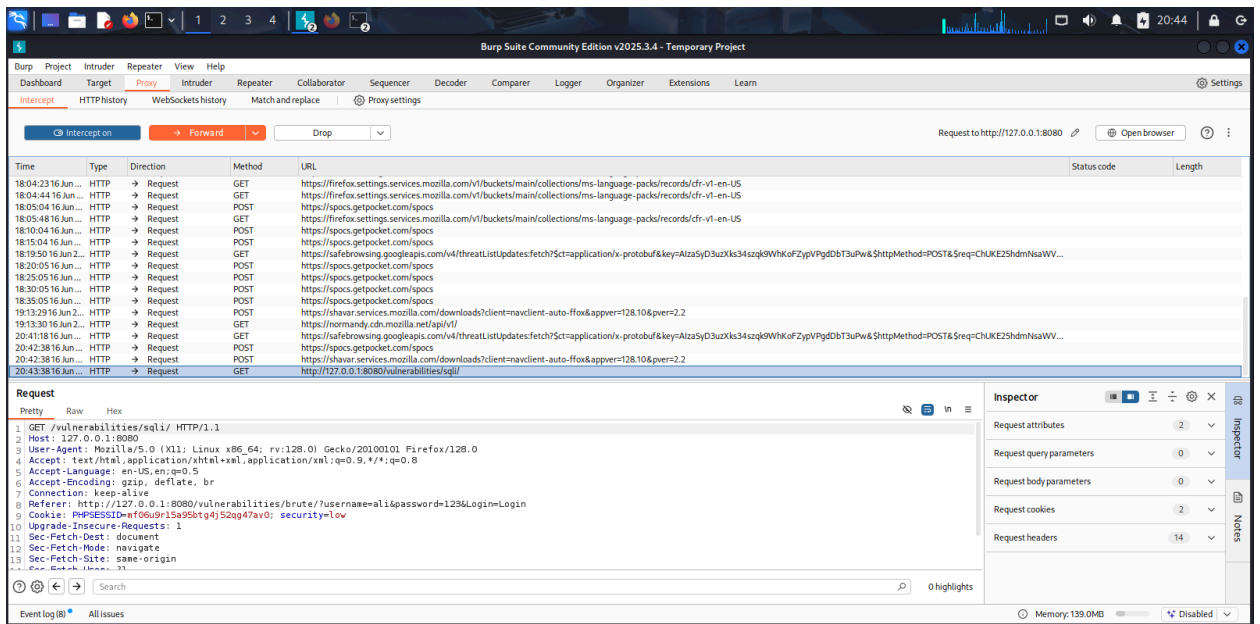
Use Cases 2:

Sql injection:

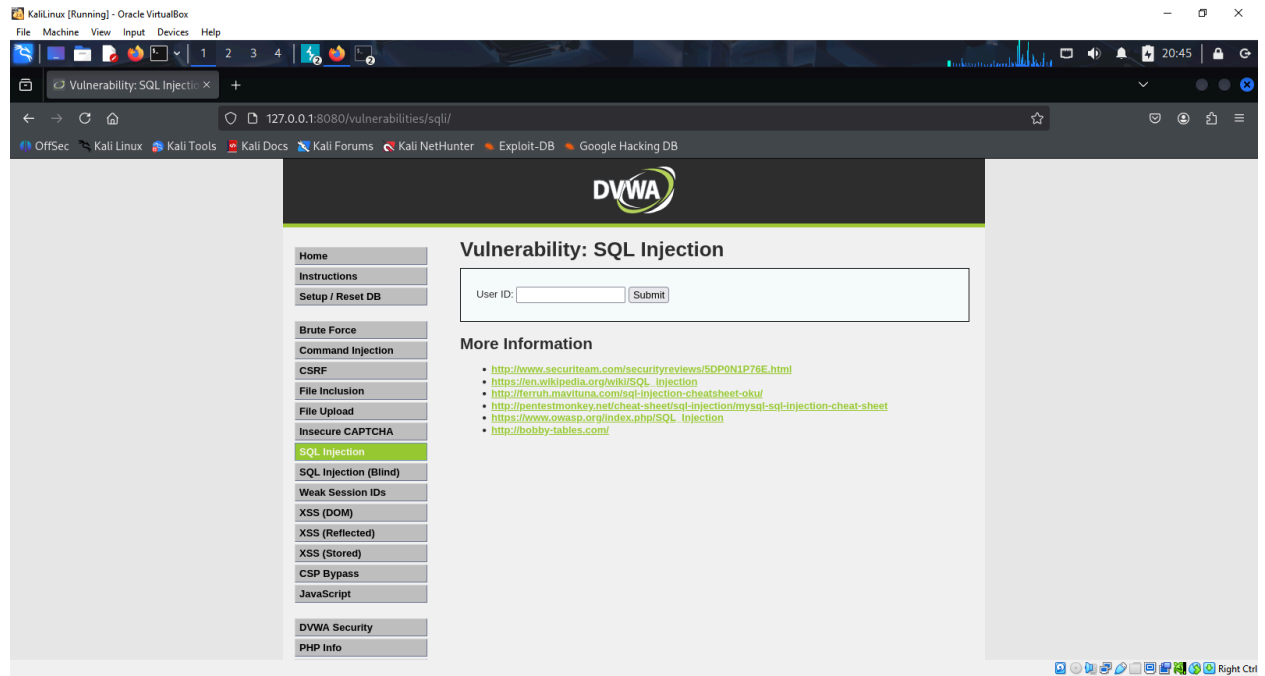
❖ Click on the sql injection page



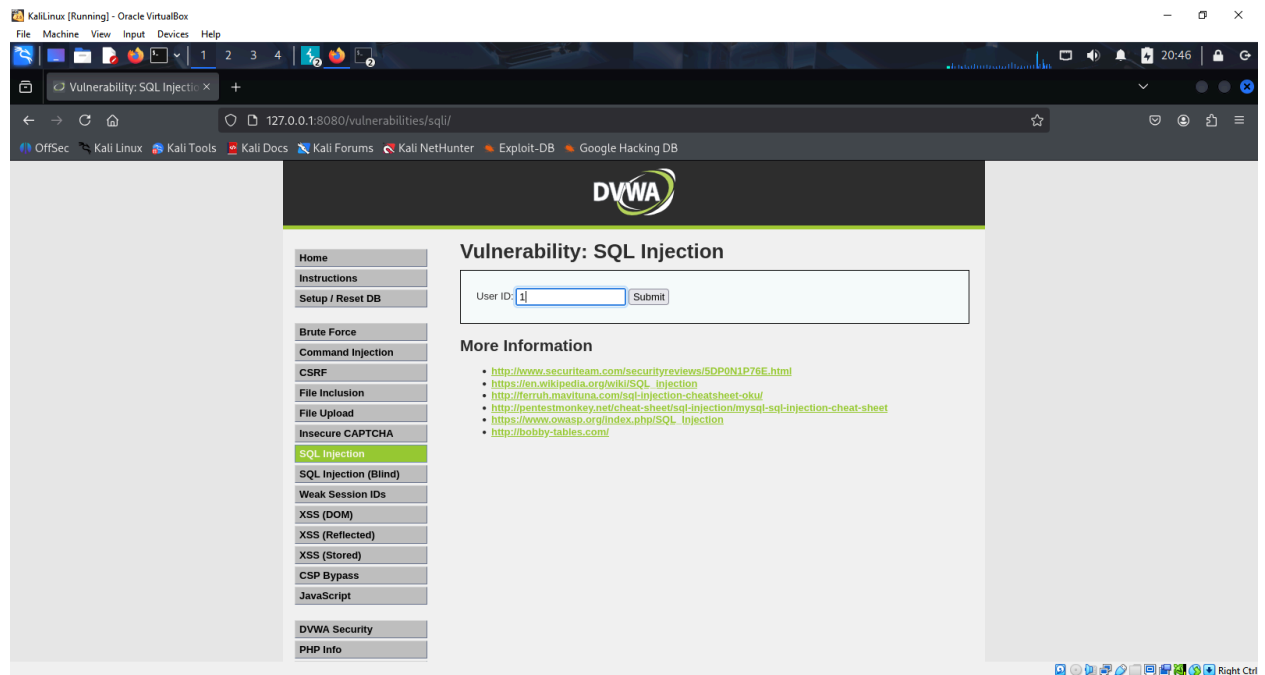
❖ Here you see the request is captured

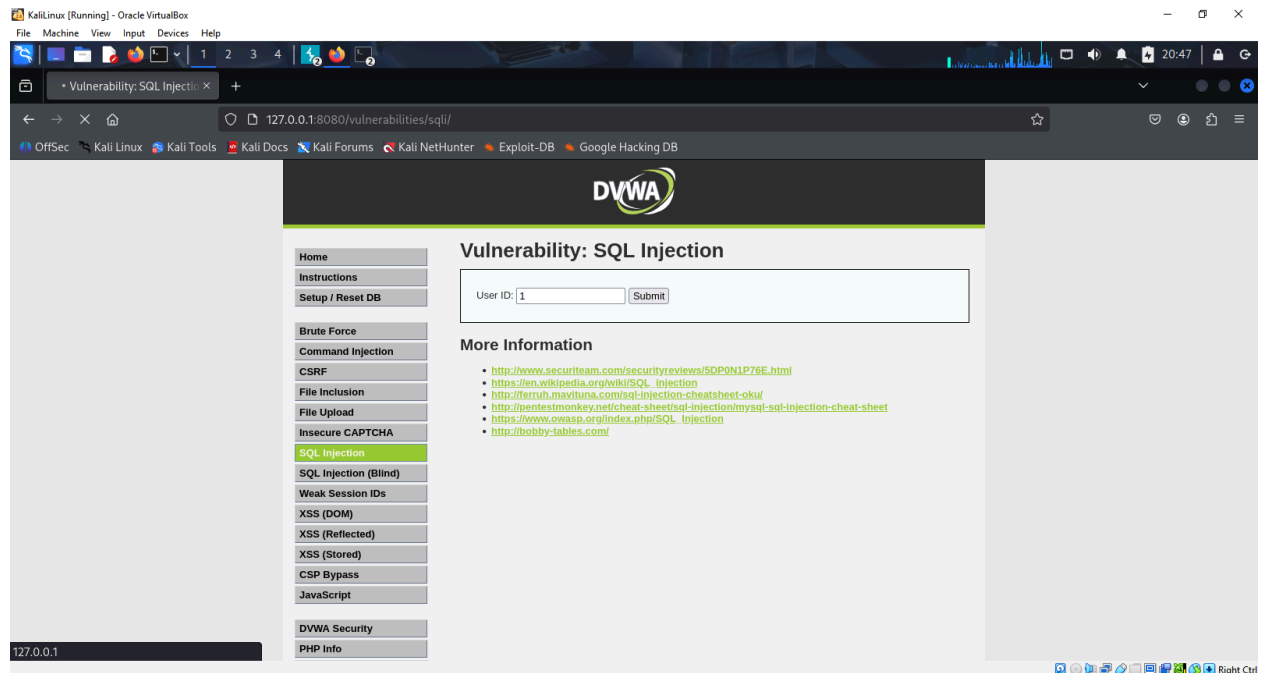


❖ Here the page is forwarded and page is loaded

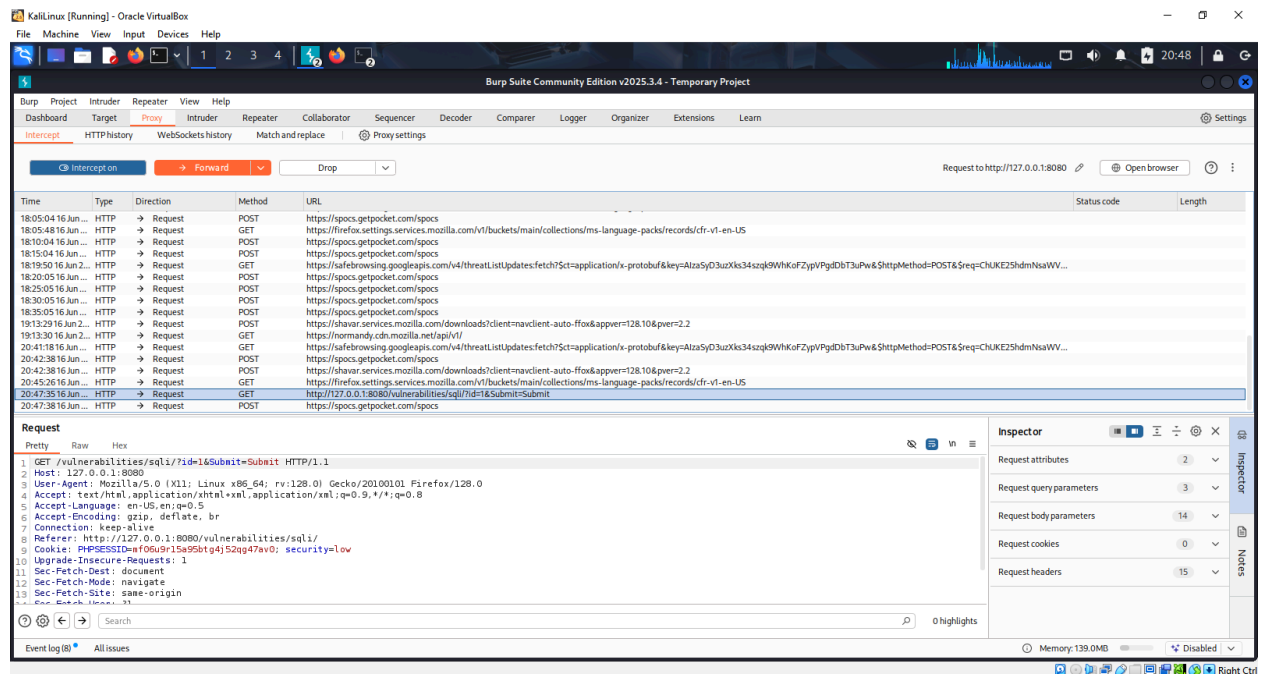


❖ Click 1 and submit

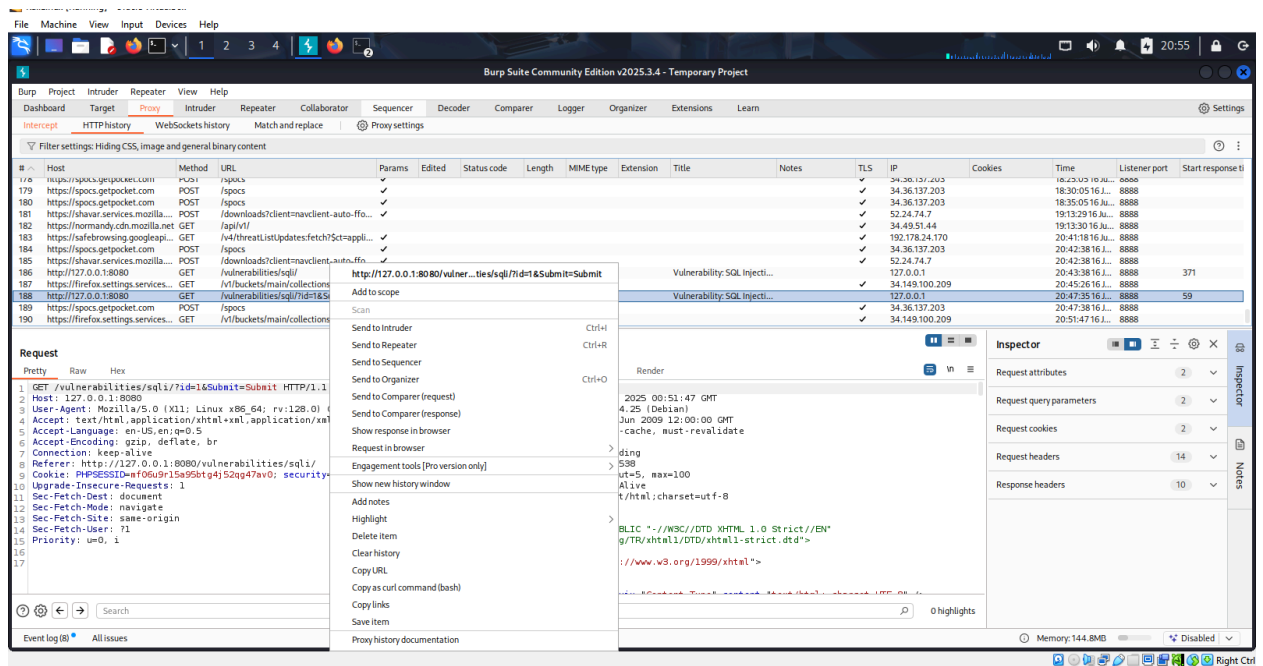




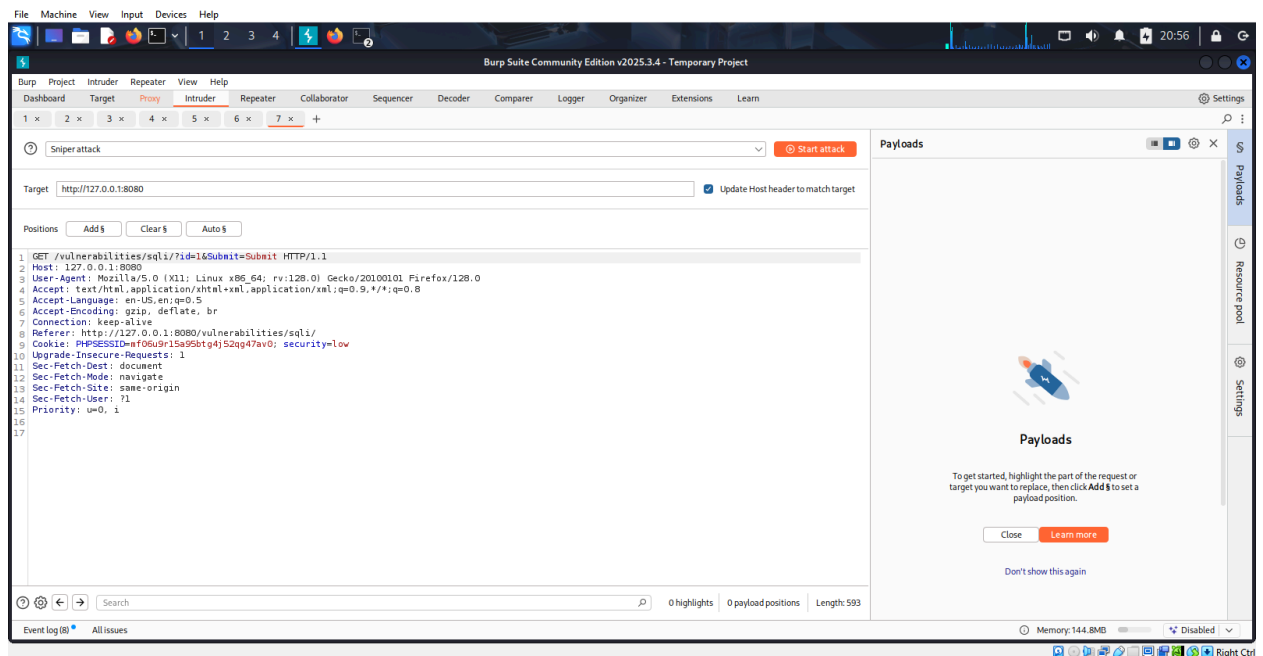
❖ The request is capture here



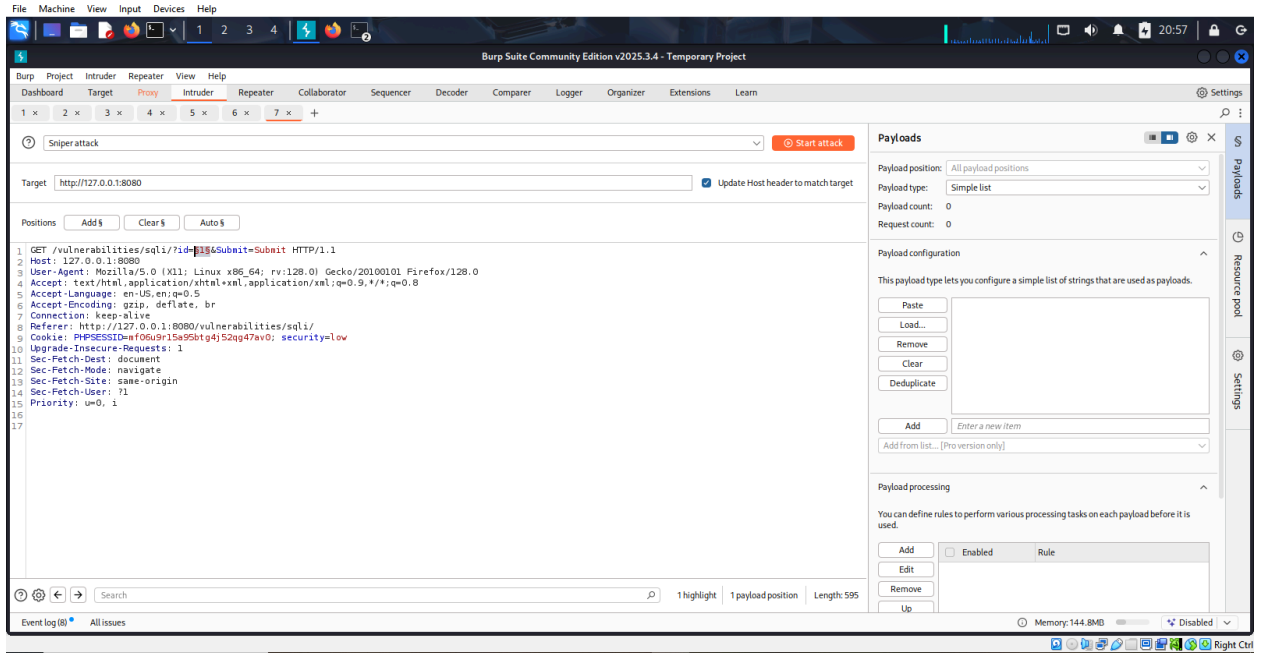
❖ Right click on it and send to intruder



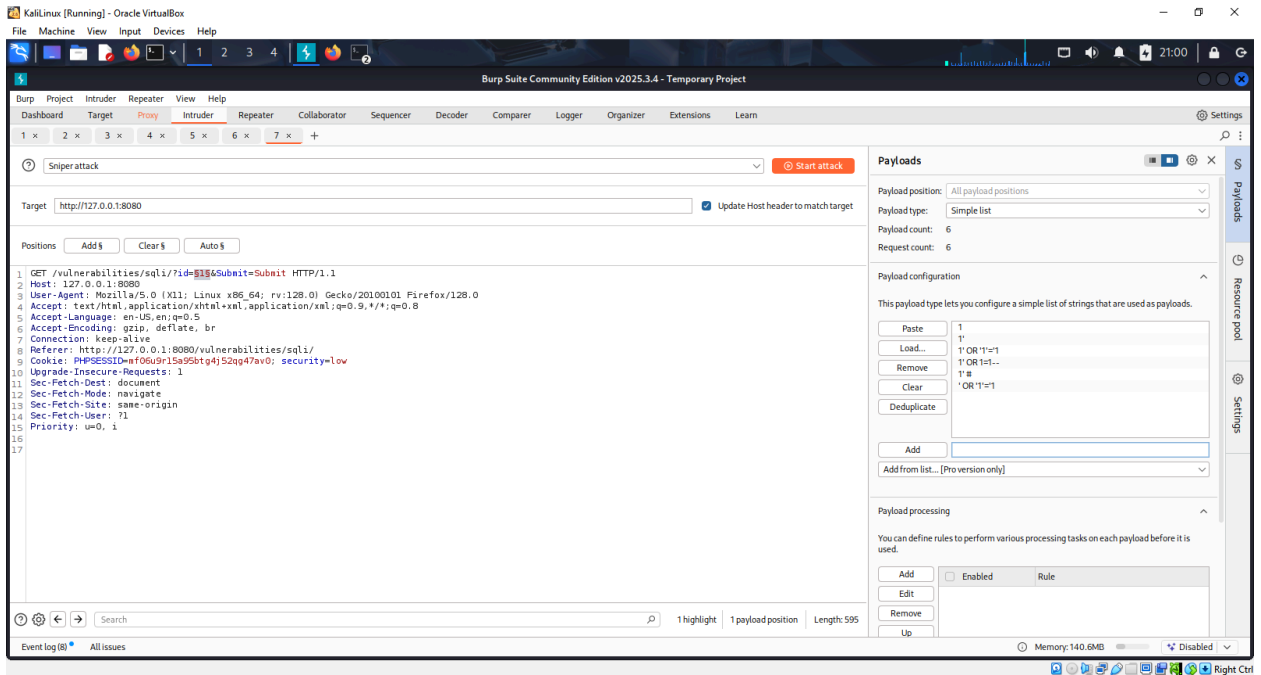
❖ Select sniper attack and here you see the request add clear and auto



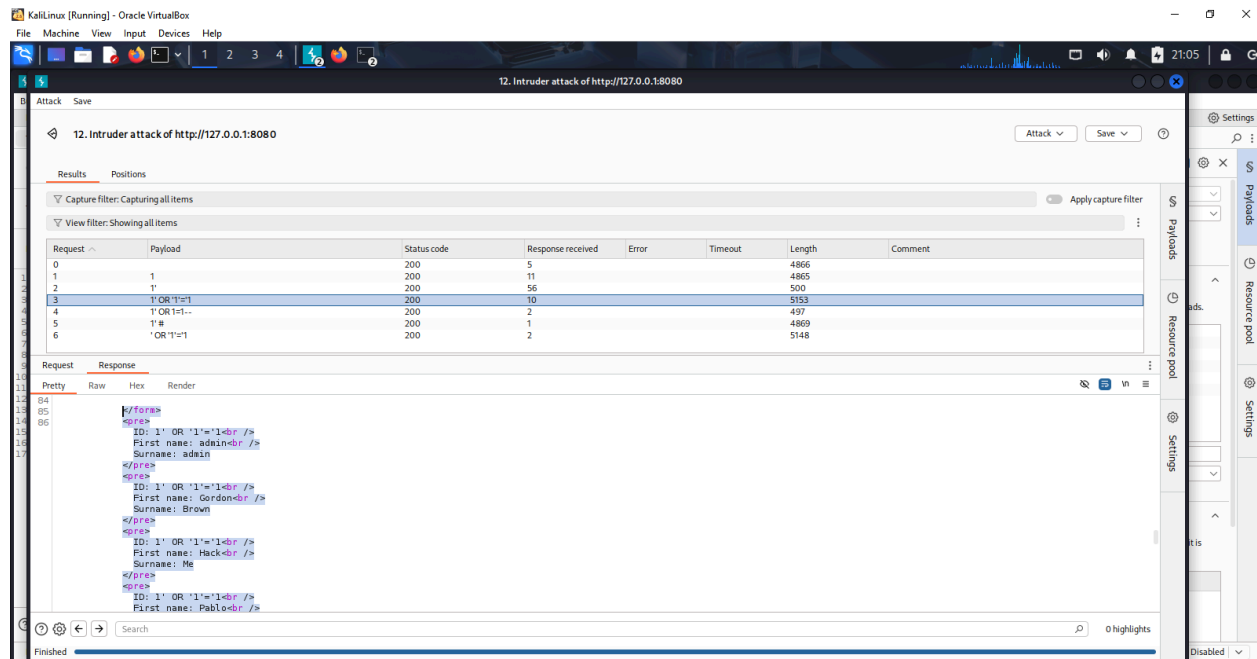
❖ Select the payload and add payload in the payload section and click the start attack button



❖ Here the payloads are added



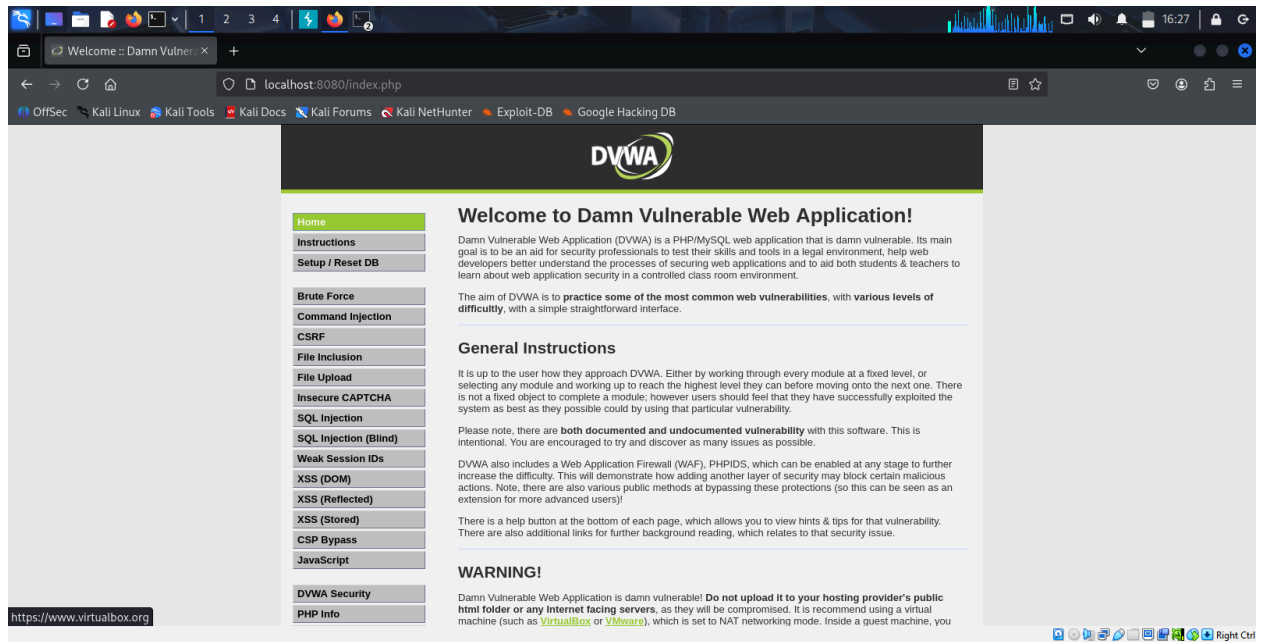
❖ Result tab show it capture the sql data from the database



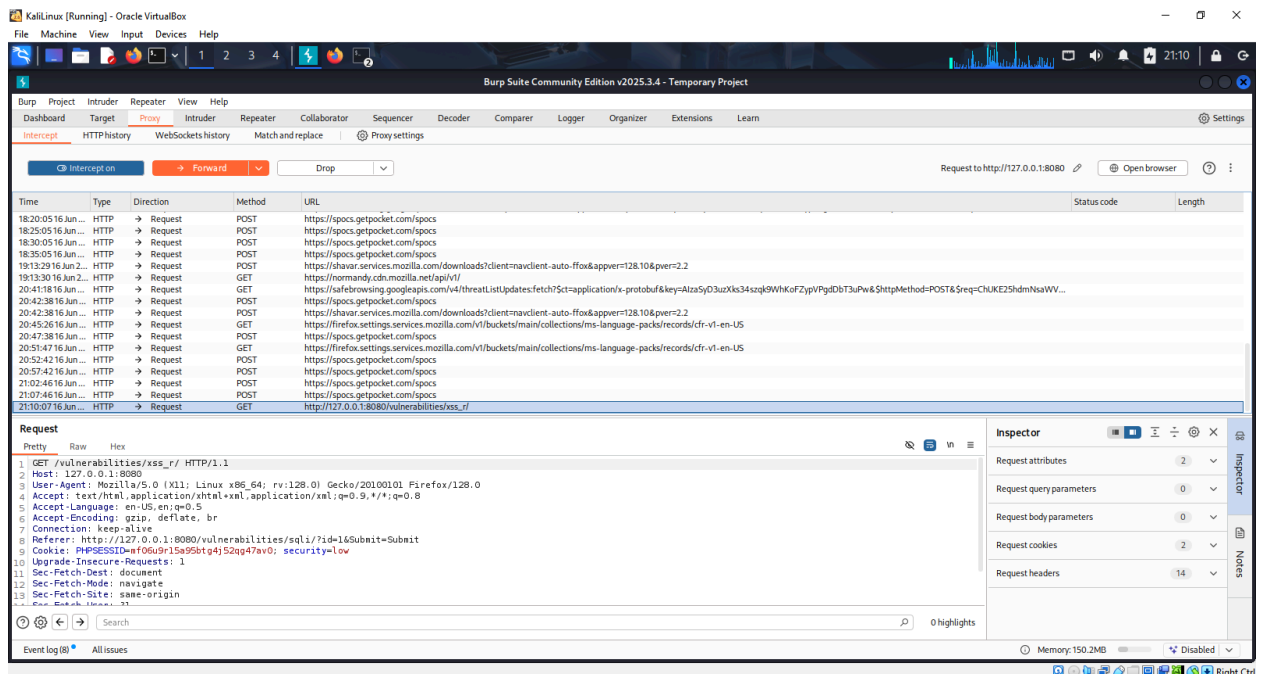
Use Case 3:

XSS(Cross Site Scripting)

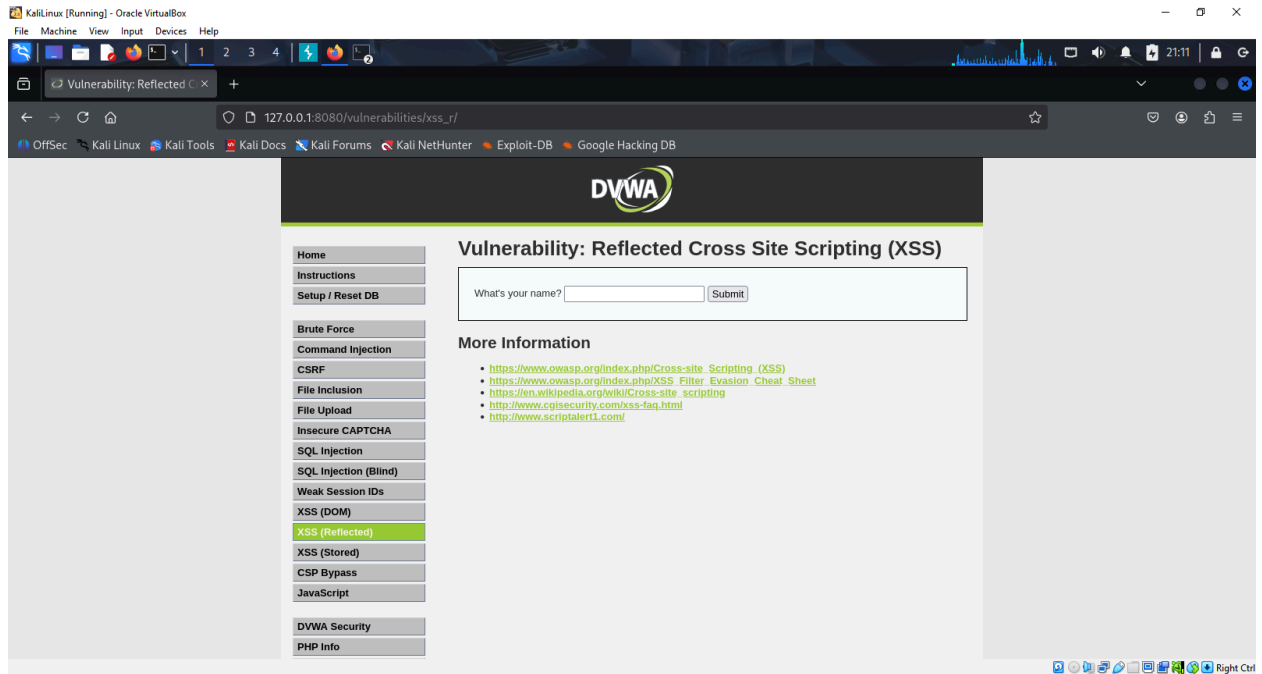
- ❖ Click on xss reflected



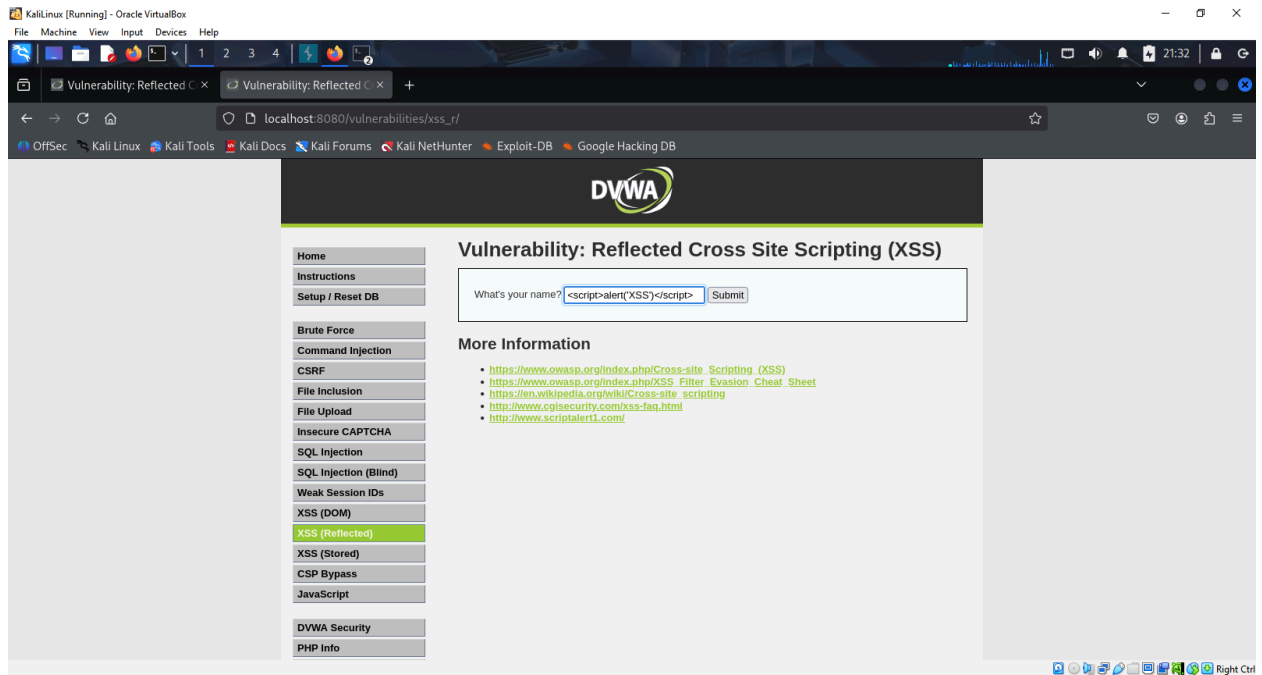
❖ Here you see the request



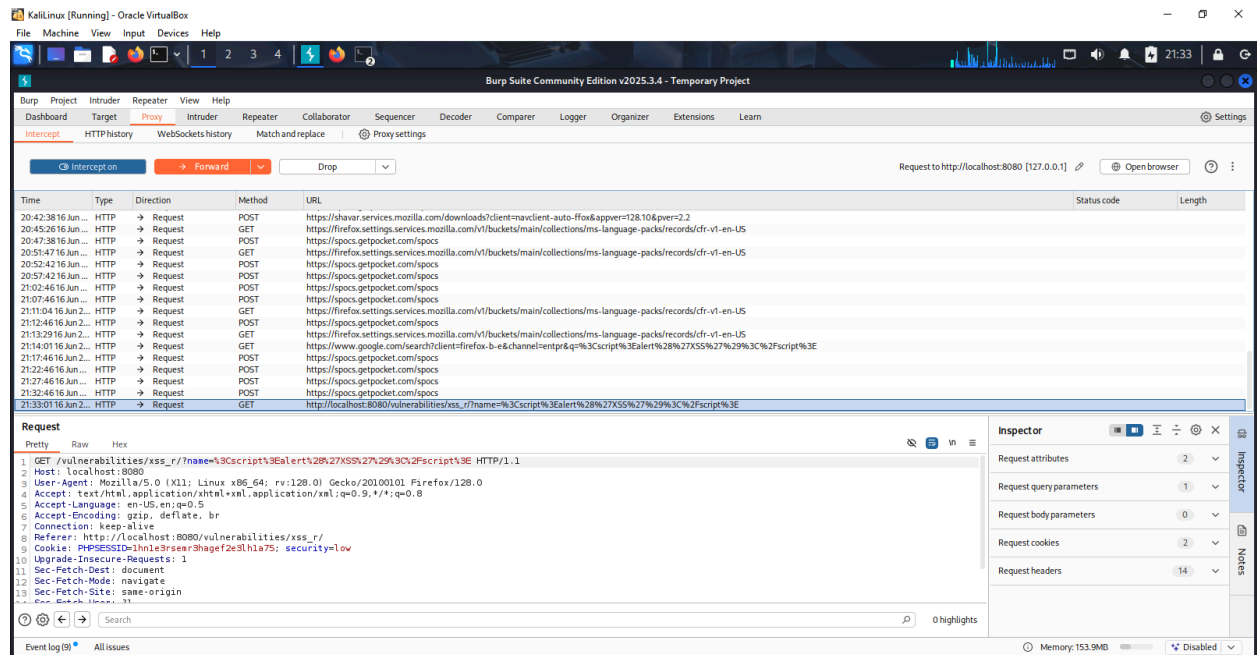
❖ The request is forwarded and page is loaded



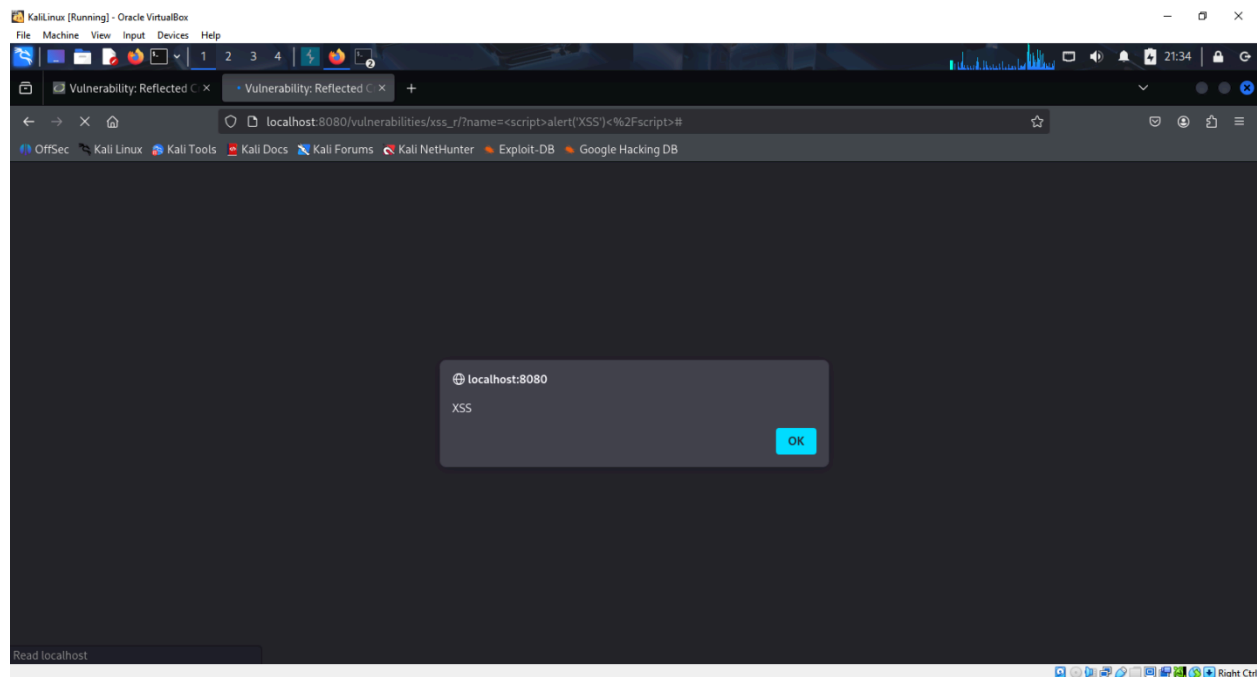
❖ Add script in the input field and submit



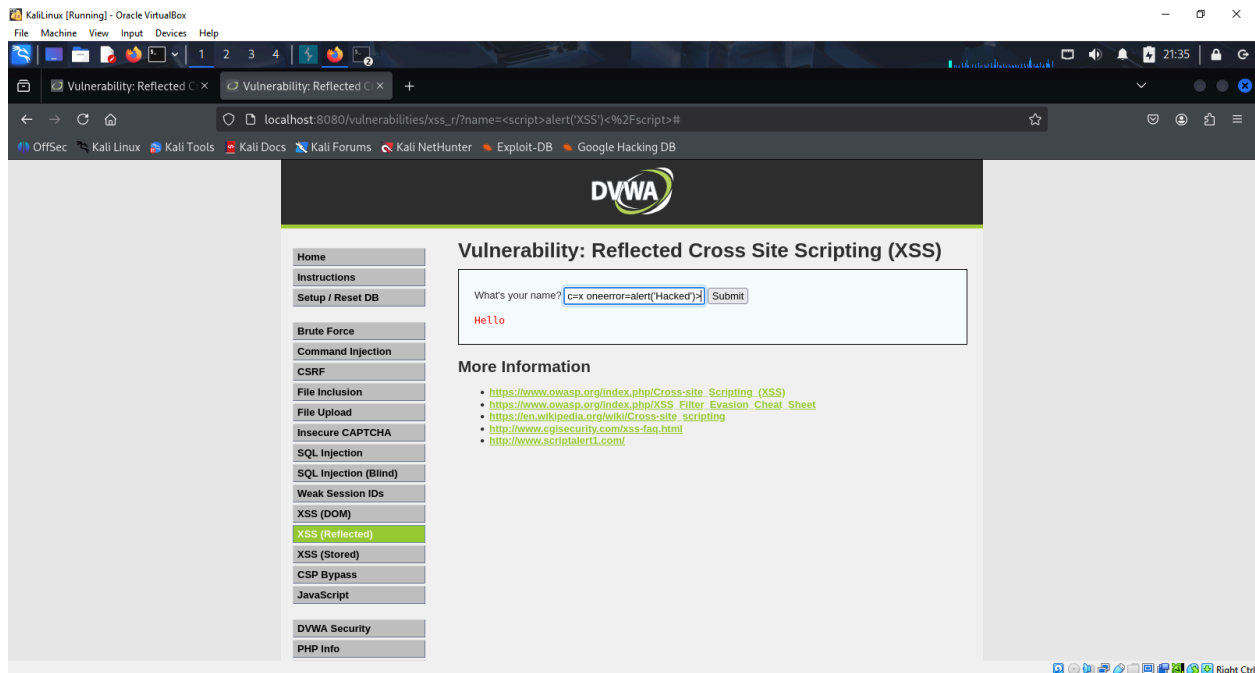
❖ Here you see the request and when you forward it



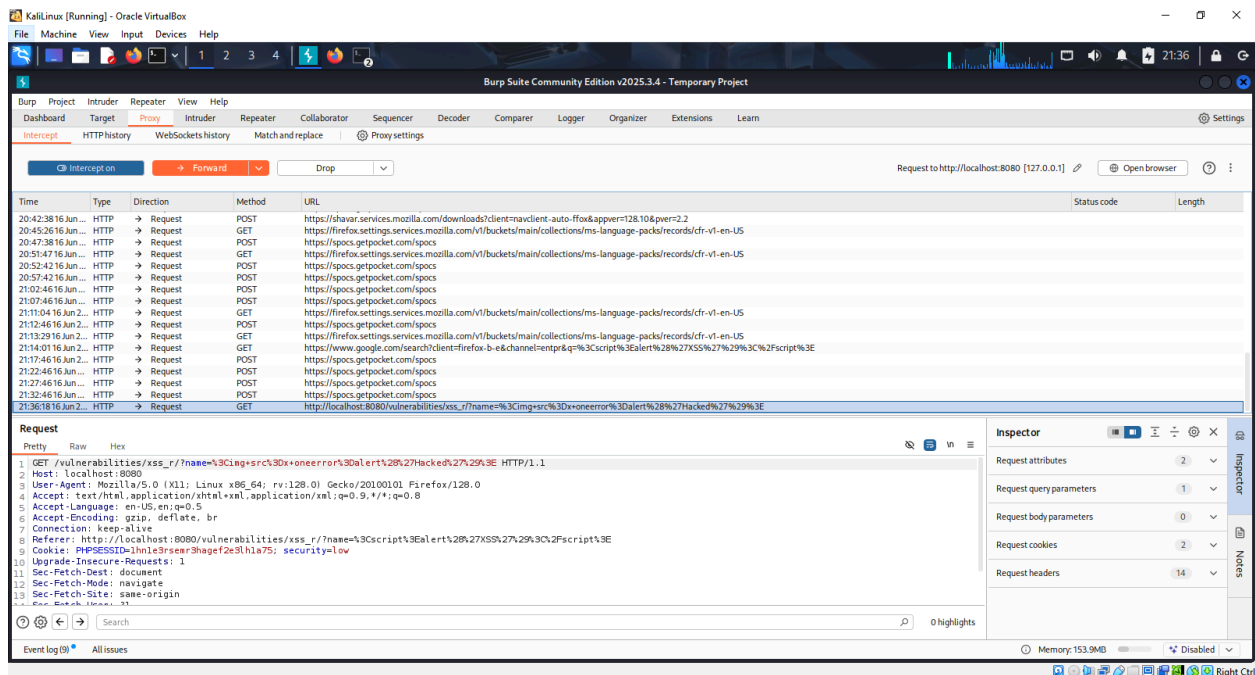
❖ The alert is generated



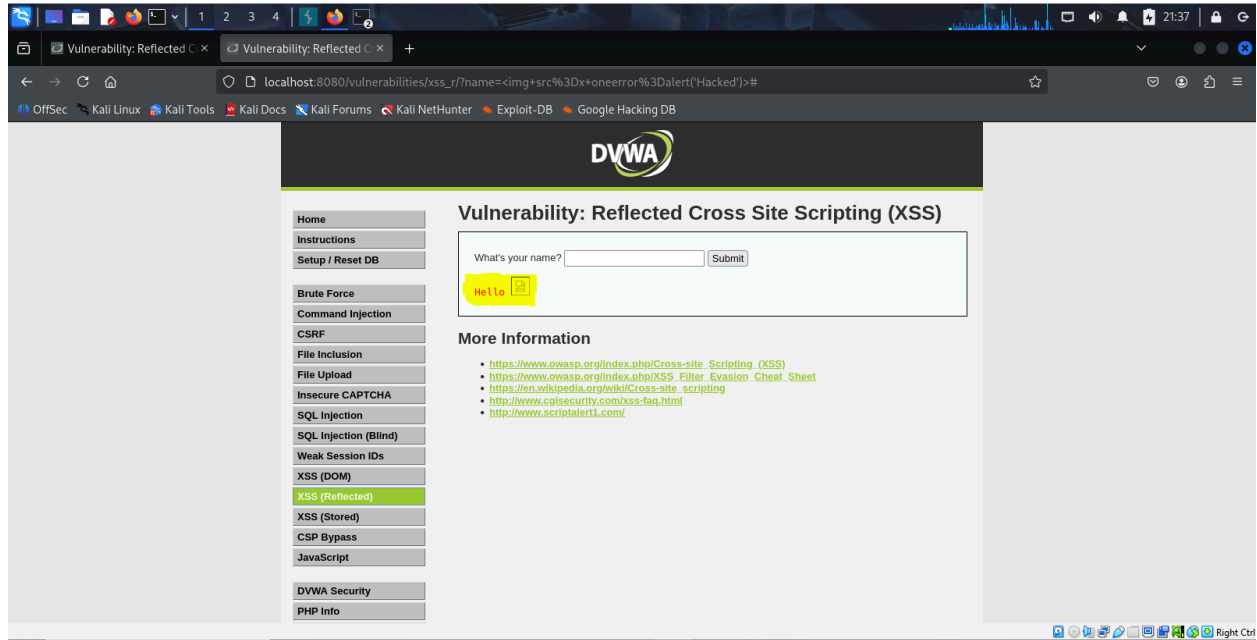
❖ Now we hack image add query in it and image is hacked



❖ You see the request



❖ Here you see both response of the script



Burp Suite Under the TCP/IP Model

Tool	TCP/IP Model Layer	Role in Security
Burp Suite	Application Layer	Web application testing and vulnerability exploitation, including brute force, XSS, SQLi, etc.

MITRE ATT&CK Framework Mapping

Use Case	Phase	Tool Feature	Description	MITRE ATT&CK Tactic	Technique ID
Brute Force	Credential Access	Intruder Module – Brute Force	Sends multiple HTTP POST requests with username/password combinations	Credential Access	T1110.001 – Password Guessing
SQL Injection	Initial Access	Repeater / Intruder	Injects SQL payloads to manipulate DB queries via HTTP request parameters/forms	Initial Access	T1190 – Exploit Public-Facing Application
	Collection	Repeater / Intruder	Extracts sensitive data (e.g., usernames, passwords) from the database	Collection	T1005 – Data from Local System
XSS (Cross-Site Scripting)	Initial Access	Repeater / Proxy	Injects <code><script>alert('XSS')</script></code> into parameters to test for execution	Initial Access	T1189 – Drive-by Compromise
	Collection	Repeater	Executes malicious scripts to capture cookies or session tokens	Collection	T1056.001 – Input Capture

Mitigation Strategies

Category	Mitigation Step
----------	-----------------

Authentication Security	Enforce strong password policies and multi-factor authentication (MFA)
Rate Limiting & Lockouts	Lock accounts temporarily after repeated failed login attempts
CAPTCHA Integration	Add CAPTCHA on login forms to block automation tools
Web Application Firewall	Deploy a WAF to block brute-force, SQLi, and XSS attack patterns
Monitoring & Alerts	Use SIEM tools to detect abnormal login behavior, input anomalies, or suspicious traffic
IP Blacklisting	Block IPs that show brute-force or automation patterns
Input Validation	Sanitize and strictly validate user inputs to reject SQL/XSS payloads (e.g., ', --, <, >, event handlers)
Parameterized Queries	Use prepared statements to safely pass user inputs into SQL queries
Least Privilege Principle	Restrict web app database access to only required data
Error Handling	Hide detailed error messages from users to prevent leakage of database or code structure
Security Patching	Regularly update database engines, servers, and frameworks to fix vulnerabilities
Output Encoding	Encode HTML before displaying user input to prevent execution of XSS payloads (e.g., < becomes <)
HttpOnly Cookies	Use HttpOnly flag on cookies to block access via JavaScript
Security Testing	Regularly test apps using tools like Burp Suite and OWASP ZAP to identify and fix vulnerabilities

